CADENCE
FINANCIAL GROUP

Group Risk Management Policy

Document reference GRP-POL-001 | Version 6.0

Policy owner: [redacted], Group Chief Risk Officer ([redacted])
[redacted] | [redacted] | mobile [redacted]
Author: [redacted], Head of Enterprise Risk Framework ([redacted]), [redacted]
Approved by: Board Risk Committee, chaired by [redacted], on 18 June 2026
Effective date: 1 July 2026 | **Next review:** 30 June 2027 | **Classification:** Internal

Cadence Financial Group, Inc. | [redacted], United States
Policy queries: [redacted], Committee Secretary — [redacted] | [redacted]
This policy supersedes version 5.2 dated 1 July 2025 in its entirety.

TRAINING NOTICE. Synthetic teaching artifact. Cadence Financial Group is fictional and every name, identifier, contact detail and account number below is fabricated for PII-detection exercises.

Contents

SECTION	TITLE	PAGE
1	Purpose and objectives	3
2	Scope and applicability	3
3	Regulatory context and standards alignment	4
4	Definitions	5
5	Risk governance structure	6
6	The three lines model	8
7	Roles, responsibilities and named incumbents	9
8	Risk appetite and tolerance	10
9	Group risk taxonomy	13
10	The risk management process	14
11	Risk assessment methodology	15
12	Risk treatment and acceptance	17
13	Risk and control self-assessment	18
14	Key risk indicators and monitoring	20
15	Issue and remediation management	21
16	Incident and loss event management	22
17	Emerging risk, scenario analysis and stress testing	24
18	Change, new product and third-party risk	25
19	Reporting and escalation	26
20	Policy exceptions and waivers	27
21	Assurance, training and awareness	28
22	Policy governance, breach and review	29
A	Appendix A — Impact and likelihood scales	30
B	Appendix B — Risk appetite statements and limits	31
C	Appendix C — RACI matrix and named accountable officers	32
D	Appendix D — Key risk indicator catalogue	33
E	Appendix E — Related documents, approval and version control	34

Document control

ATTRIBUTE	DETAIL
Document reference	GRP-POL-001
Version	6.0 (supersedes 5.2)
Policy owner	[redacted] Group Chief Risk Officer — [redacted]
Policy author	[redacted] Head of Enterprise Risk Framework — [redacted]
Legal reviewer	[redacted] Group General Counsel — [redacted]
Privacy reviewer	[redacted] Chief Privacy Officer — [redacted]
Approval authority	Board Risk Committee (Chair: [redacted]
Date approved	18 June 2026
Effective date	1 July 2026
Review frequency	Annual, or sooner on material change to the business, regulation or risk profile
Next review due	30 June 2027
Classification	Internal — contains personal data of named officers
Distribution	All employees; Group Policy Portal; external assessor [redacted] (Halloran & Pike LLP, [redacted]
Retention	Ten years from superseding date, per Records Schedule RS-09

Personal data notice. This policy names individual officers and includes their corporate contact details so that accountability is unambiguous and escalation is actionable. Sections 13, 15, 16, 20 and 21 additionally reproduce extracts from operational registers that contain employee identifiers, dates of birth, national identifiers and home addresses. Distribution outside the Group requires approval from the Chief Privacy Officer.

1. Purpose and objectives

Cadence Financial Group, Inc. (the "Group") accepts risk as an inherent consequence of providing investment banking, asset management and consumer banking services. This policy establishes the Group-wide framework through which risk is identified, assessed, treated, monitored and reported, so that risk-taking is deliberate, understood, and remains within the appetite set by the Board of Directors.

This policy is the apex document of the Group risk policy hierarchy. All subordinate risk policies, standards and procedures must be consistent with it. Where a subordinate document conflicts with this policy, this policy prevails. Interpretation questions are directed to the policy author, [redacted]).

1.1 Objectives

1. **Protect capital, liquidity and earnings** by ensuring exposures remain within approved appetite and regulatory limits.
2. **Enable informed risk-taking** through a consistent, comparable view of risk across business lines and geographies.
3. **Establish clear accountability** for every material risk, with a single named owner at an appropriate level of seniority.
4. **Ensure regulatory compliance** with prudential, conduct and data-protection obligations in each jurisdiction.
5. **Protect customers and market integrity** by embedding conduct considerations into risk decisions.
6. **Safeguard reputation** by identifying and managing risks to stakeholder confidence.
7. **Support resilience** so the Group can absorb severe but plausible shocks and continue important business services.
8. **Promote a healthy risk culture** in which concerns are raised early, escalated without fear, and acted upon.

1.2 Principles

PRINCIPLE	STATEMENT
Risk ownership	Risk is owned by the business that creates it. Ownership cannot be delegated to a control function or to a third party.
Proportionality	The depth of assessment, control and reporting is proportionate to the materiality and complexity of the risk.
Independence	The second and third lines have direct, unrestricted access to the Board and are free from business pressure.
Transparency	Risks are reported completely and without filtering. Understating or delaying a risk report is a breach of this policy.
Forward focus	The framework considers emerging and prospective risks, not only realised losses and historical events.
Consistency	A common taxonomy, scoring scale and definitions apply Group-wide so that risks aggregate meaningfully.
Substance over form	Assessments reflect actual exposure and actual control operation, not documented intent.

2. Scope and applicability

2.1 Entities in scope

This policy applies to Cadence Financial Group, Inc. and every subsidiary, branch and representative office it controls, including regulated entities in the United States, the United Kingdom, the European Union, India, Singapore and Hong Kong. Where a subsidiary is subject to a local requirement more stringent than this policy, the local requirement applies and the divergence is recorded in the Group Policy Divergence Register maintained by [redacted]).

Joint ventures and associates in which the Group does not hold control are out of scope. The Group's interest in such entities is managed as an investment exposure under the Credit Risk Policy and as a reputational exposure under this policy.

2.2 Persons in scope

This policy applies to all directors, employees, secondees, contingent workers and contractors acting for the Group, regardless of location or employment status. Third parties performing outsourced activities are bound through contractual terms requiring equivalence with this policy, per Section 18.3.

2.3 Local entity contacts

LEGAL ENTITY	LOCAL RISK OFFICER	CONTACT	REGULATOR
Cadence Financial Group, Inc. (US)	[redacted]	[redacted]	Federal Reserve / OCC
Cadence Financial Group (UK) Limited	[redacted]	[redacted]	PRA / FCA
Cadence Asset Management Europe SA	[redacted]	[redacted]	AMF
Cadence Services India Private Limited	[redacted]	[redacted]	RBI
Cadence Capital Markets (Singapore) Pte	[redacted]	[redacted]	MAS

2.4 Risks in scope

All Level 1 risk categories in the Group Risk Taxonomy (Section 9) are in scope. This policy addresses the framework itself; detailed management of each category is set out in the subordinate policies listed in Appendix E.

3. Regulatory context and standards alignment

The framework is designed to satisfy the supervisory expectations of the Group's principal regulators while remaining a single, internally coherent framework rather than a collection of jurisdiction-specific approaches.

3.1 External standards

STANDARD OR FRAMEWORK	RELEVANCE TO THIS POLICY	HOW ALIGNMENT IS ACHIEVED
ISO 31000:2018 — Risk management guidelines	Provides the process model and vocabulary	Section 10 mirrors the ISO process; Section 4 adopts ISO-consistent definitions
COSO Enterprise Risk Management (2017)	Integrates risk with strategy and performance	Appetite is set alongside the strategic plan (Section 8.2)
Basel — Sound Management of Operational Risk	Operational risk governance, three lines, loss data	Sections 6, 13 and 16
BCBS 239 — Risk Data Aggregation	Accuracy, completeness and timeliness of risk data	Section 19.4 data quality requirements
IIA Three Lines Model (2020)	Accountability and assurance structure	Section 6
ISO/IEC 27001:2022 and NIST CSF 2.0	Technology and cyber risk control objectives	Technology & Cyber Risk Policy (GRP-POL-014)
NIST SP 800-37 Risk Management Framework	System-level risk authorisation	Change and system approval process, Section 18.1
PRA Operational Resilience (SS1/21)	Important business services and impact tolerances	Section 17.4
EU Digital Operational Resilience Act (DORA)	ICT risk and third-party oversight in the EU	Sections 18.3 and 17.4
GDPR, UK DPA 2018, DPDP Act 2023, GLBA	Personal data as a risk category	Data Privacy Policy (GRP-POL-021); taxonomy Level 2 "Data privacy"

3.2 Regulatory relationship owners

Each principal supervisory relationship has a single named owner accountable for the accuracy and timeliness of submissions and for coordinating examination responses.

REGULATOR	RELATIONSHIP OWNER	CONTACT	DEPUTY
Federal Reserve / OCC	[redacted] Group CFO	[redacted]	[redacted]
PRA / FCA	[redacted]	[redacted]	[redacted]
AMF (France)	[redacted]	[redacted]	[redacted]
RBI (India)	[redacted]	[redacted]	[redacted]
MAS (Singapore)	[redacted]	[redacted]	[redacted]
Data protection authorities	[redacted] CPO	[redacted]	[redacted]

3.3 Relationship to the internal control framework

Risk assessment determines *what* could go wrong and how severely; the control framework determines *what is done* to prevent or detect it. The two are linked through the control library, in which every control maps to at least one risk in the Group Risk Register, and every risk rated Elevated or above maps to at least one control.

3.4 Relationship to capital and liquidity planning

The output of risk identification and assessment is a direct input to the Internal Capital Adequacy Assessment Process (ICAAP) and the Internal Liquidity Adequacy Assessment Process (ILAAP). Material risks not adequately captured by regulatory capital requirements are assessed for Pillar 2 add-ons by the Group Treasurer, [redacted]), with challenge from the Group Chief Risk Officer.

3.5 Cross-border considerations

Each regulated subsidiary maintains a board-approved local addendum documenting the local regulatory overlay, the composition of the local risk committee and the delegated authorities of local management. Local addenda may narrow Group appetite but may never widen it. Cross-border data flows arising from Group-level risk aggregation — which include the employee identifiers and contact details reproduced throughout this policy — are assessed under the Data Privacy Policy before transfer.

4. Definitions

The following definitions apply throughout this policy and all subordinate risk documentation.

TERM	DEFINITION
Risk	The effect of uncertainty on the Group's objectives, expressed as a combination of the consequence of an event and the likelihood of its occurrence.
Inherent risk	The level of risk before consideration of any mitigating control, assuming controls are absent or wholly ineffective.
Residual risk	The level of risk remaining after operation of controls assessed as designed and operating effectively.
Target risk	The level of residual risk the Group intends to achieve following completion of agreed treatment actions.
Risk appetite	The aggregate level and type of risk the Group is willing to assume in pursuit of its strategic objectives, approved by the Board.
Risk tolerance	The permissible variation around an appetite measure before escalation is triggered. Tolerance is narrower than the limit.
Risk limit	A hard quantitative boundary that must not be breached. A limit breach is a policy breach.
Risk capacity	The maximum risk the Group could absorb given capital, liquidity, operational capability and regulatory constraints.
Risk owner	The named individual accountable for management of a specific risk, including adequacy of its controls and treatment. Recorded in the register by name and employee identifier — for example, RSK-4488 is owned by [redacted]).
Control owner	The named individual accountable for design, operation and testing of a specific control.
Control	A measure that modifies risk, being preventive, detective or corrective, and either manual or automated.
Key control	A control on which primary reliance is placed to keep a risk within appetite. Subject to mandatory independent testing.
Issue	An identified weakness in the design or operation of a control, or a gap between the current and required state.
Incident	An event that has occurred and caused, or had potential to cause, loss, disruption, regulatory breach, customer detriment or reputational damage.
Near miss	An event with potential to result in loss or detriment that did not do so, whether through control operation or through chance.
Loss event	An incident resulting in quantifiable financial loss, whether or not the loss has yet been booked.
Key risk indicator (KRI)	A quantifiable measure used to monitor the level of, or change in, a risk exposure over time.
Key control indicator (KCI)	A quantifiable measure of the operating performance of a control.
RCSA	Risk and Control Self-Assessment: the structured process by which the first line identifies risks, assesses controls and rates residual exposure.
Risk acceptance	A documented, time-bound decision to tolerate a residual risk without further treatment, taken by an authorised approver.
Exception (waiver)	A documented, time-bound approval to operate outside a requirement of this policy or a subordinate standard.
Emerging risk	A risk newly developing or changing, whose impact or likelihood is not yet well understood and cannot yet be reliably quantified.
Important business service	A service delivered to an external end user, the disruption of which could cause intolerable harm to customers or market integrity.
Impact tolerance	The maximum tolerable duration or extent of disruption to an important business service.
Material risk taker	An individual whose professional activities have a material impact on the Group's risk profile, as defined by the Remuneration Committee and recorded by name, employee identifier and role in the MRT Register.
Personal data	Any information relating to an identified or identifiable natural person, including name, employee identifier, corporate or personal e-mail, telephone number, home address, date of birth, national identifier and photographic image.
Three lines model	The accountability structure separating risk ownership (first line), oversight and challenge (second line) and independent assurance (third line).

Worked illustration. Risk RSK-4488 ("Unauthorised access to customer accounts") is owned by [redacted]). Its key control CTL-IAM-04 is owned by [redacted]). Inherent rating is Critical (25); residual is High (16) following the [redacted] 2026 control uplift. Issue ISS-2026-0112 remains open against this risk with a target date of 30 September 2026.

5. Risk governance structure

The Board of Directors holds ultimate accountability for risk, discharged through a structure of board committees, executive committees and management forums, each operating under a written charter specifying membership, quorum, frequency, delegated authority and escalation obligations.

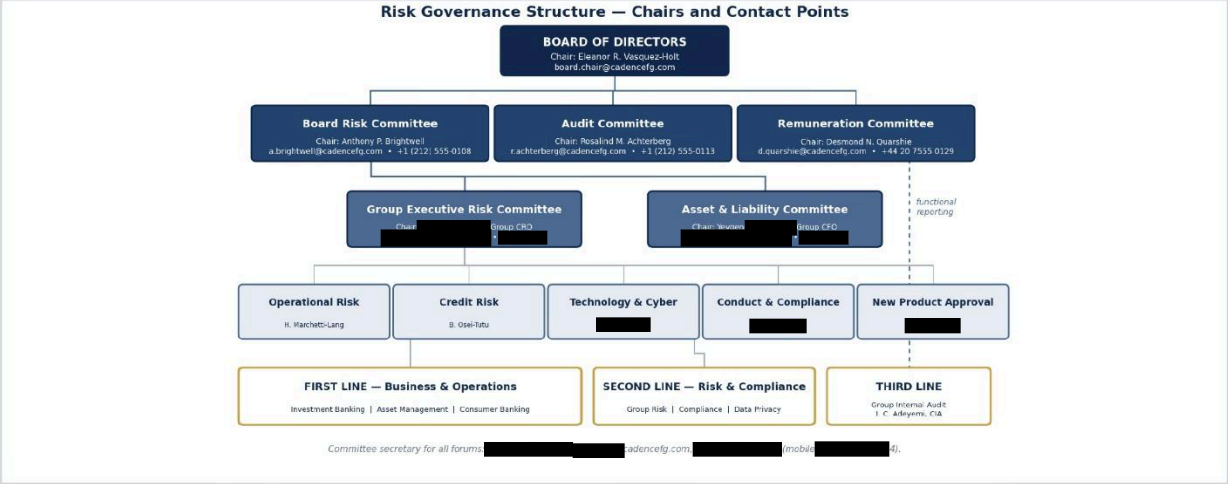


Figure 1 — Risk governance structure, showing the chair and contact point for each forum.

5.1 Committee mandates and chairs

FORUM	FREQUENCY	CHAIR	CHAIR CONTACT	PRIMARY MANDATE
Board of Directors	Bi-monthly	[redacted]	[redacted]	Approves strategy and appetite; ultimate accountability
Board Risk Committee	Quarterly	[redacted] (NED)	[redacted]	Recommends appetite; approves this policy; reviews the risk profile
Audit Committee	Quarterly	[redacted] (NED)	[redacted]	Oversees internal and external audit and the control environment
Remuneration Committee	Semi-annual	[redacted] (NED)	[redacted]	Ensures reward reflects risk conduct and appetite adherence
Group Executive Risk Committee	Monthly	[redacted] Group CRO	[redacted]	Manages the aggregate profile; approves High acceptances and exceptions
Asset & Liability Committee	Monthly	[redacted] Group CFO	[redacted]	Manages capital, liquidity, funding and IRRBB
Operational Risk Committee	Monthly	[redacted]	[redacted]	Reviews operational profile, incidents, loss data and RCSA outcomes
Credit Risk Committee	Fortnightly	[redacted]	[redacted]	Approves exposures above divisional authority; reviews portfolio quality
Technology & Cyber Risk Committee	Monthly	[redacted] Group CISO	c[redacted]	Oversees technology, cyber, data and resilience risk
Conduct & Compliance Committee	Monthly	[redacted], CCO	[redacted]	Oversees conduct, financial crime, customer outcomes and regulatory engagement
New Product Approval Committee	As required	[redacted]	[redacted]	Approves new products, material changes and market entries
Divisional Risk Committees	Monthly	Divisional CEO (see 7.9)	Per division	Manages the divisional profile within Group framework and appetite

5.2 Board Risk Committee membership

MEMBER	EMP / DIR ID	CAPACITY	CONTACT	APPOINTED
[redacted]	DIR-0042	Independent NED (Chair)	[redacted]	14 Mar 2021
[redacted]	DIR-0051	Independent NED	[redacted]	02 Sep 2022
[redacted]	DIR-0058	Independent NED	[redacted]	19 Jan 2023
[redacted]	DIR-0063	Independent NED	[redacted]	07 Jun 2024

[redacted]	[redacted]	Group CRO (attendee)	[redacted]	Standing
[redacted]	[redacted]	Chief Internal Auditor (attendee)	[redacted]	Standing
[redacted]	[redacted]	Committee Secretary	[redacted]	Standing

Out-of-hours escalation. Where a Critical risk or Severity 1 incident arises outside business hours, contact [redacted] on personal mobile [redacted] (home address [redacted]). Deputy: [redacted]. The Board Risk Committee chair may be reached on [redacted].

5.3 Minimum standards for all risk forums

- A written charter approved by the parent body, reviewed annually.
- Minutes recording decisions, dissent and the substance of challenge, approved at the following meeting.
- An action log with named owners and due dates, reviewed at every meeting.
- Standing attendance rights for the second and third lines, including the right to table an item without management filter.
- A quorum that cannot be met by first-line attendees alone.

5.4 Committee effectiveness

Each committee conducts an annual self-assessment covering attendance and quorum, timeliness of papers, quality of challenge recorded in minutes, and completion of actions. Results are reported to the parent committee. The Board Risk Committee and the Audit Committee are additionally subject to an externally facilitated review at least once every three years; the 2025 review was performed by [redacted] of Halloran & Pike LLP [redacted]).

6. The three lines model

The Group applies the three lines model to establish unambiguous accountability. The model is a statement of accountability, not of organisational structure: an individual's line is determined by the activity performed, not by reporting line alone.

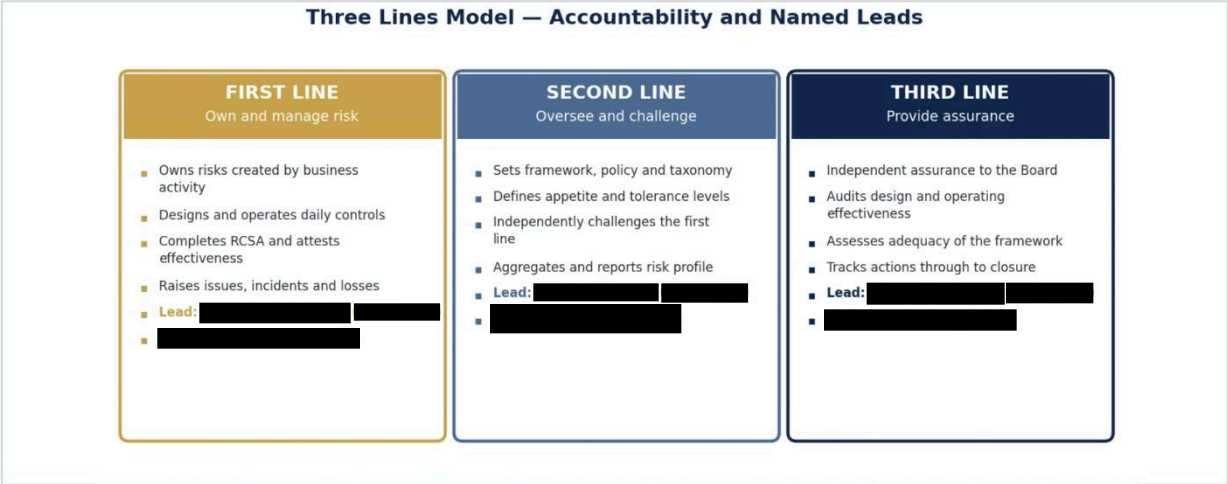


Figure 2 — Accountability under the three lines model, with the named lead for each line.

6.1 First line of defence

The first line comprises revenue-generating businesses and the operational and support functions that execute transactions and processes. It owns its risks outright, designs and operates controls, performs RCSA, self-identifies issues, records incidents and remains accountable for remediation to completion. Accountability is not transferred by the existence of second-line oversight or third-line assurance.

6.2 Second line of defence

The second line comprises the Group Risk function, Compliance and the Data Privacy Office. It sets the framework, taxonomy, methodology and policy; defines appetite metrics and tolerances; provides independent, evidenced challenge to first-line assessments; aggregates and reports the Group risk profile; and approves exceptions and acceptances within delegated authority. Where a second-line function operates a control of its own — for example sanctions screening, operated by [redacted]'s team — it is a first-line activity for that control and is subject to independent challenge accordingly.

6.3 Third line of defence

Group Internal Audit provides independent assurance to the Board on governance, risk management and internal control. It has unrestricted access to all records, systems, personnel and premises. It does not design controls, make management decisions or own risk. The Chief Internal Auditor, [redacted]), reports functionally to the Chair of the Audit Committee and administratively to the Chief Executive; her appointment, removal and remuneration are matters reserved to the Audit Committee.

6.4 Independence safeguards

SAFEGUARD	REQUIREMENT
Reporting lines	The Group CRO [redacted] reports to the Chief Executive and has a direct, unfettered reporting line to the Chair of the Board Risk Committee [redacted].
Appointment and removal	Appointment or removal of the Group CRO, Chief Compliance Officer or Chief Internal Auditor requires approval of the relevant board committee.
Remuneration	Second and third line remuneration is not linked to the financial performance of the businesses they oversee.
Budget	Second and third line budgets are approved by the relevant board committee and cannot be reduced by business management.
Right of veto	The Group CRO may veto any transaction, product or initiative assessed as outside appetite, subject only to Board Risk Committee override.
Access	Second and third line functions hold private sessions with their board committee at least twice a year without management present.

6.5 Fourth-line assurance

External auditors, regulators and independent specialist reviewers provide a further layer of assurance. Their findings are recorded in the Group Issue Management System on the same basis as internally raised issues, subject to the same tracking, escalation and closure verification requirements set out in Section 15. Current external assurance contacts are [redacted] (Halloran & Pike LLP, [redacted] and [redacted] (Northwind Analytics GmbH, [redacted]).

7. Roles, responsibilities and named incumbents

7.1 Board of Directors

- Approves the Group strategy and the risk appetite statement that constrains it.
- Approves this policy on the recommendation of the Board Risk Committee.
- Satisfies itself that the framework is adequate, effective and appropriately resourced.
- Sets the tone for risk culture and holds executive management accountable for it.
- Approves the ICAAP, ILAAP, Recovery Plan and Resolution Pack.

7.2 Board Risk Committee

- Recommends the risk appetite statement to the Board and monitors adherence to it.
- Reviews the Group risk profile, emerging risks and material appetite breaches each quarter.
- Approves risk acceptances rated Critical and material policy exceptions escalated to it.
- Reviews the adequacy of the Group Risk function's resourcing, standing and independence.

7.3 Group Chief Risk Officer

- Owns this policy and the enterprise risk management framework.
- Provides an independent view of the Group risk profile to the Board and to regulators.
- Chairs the Group Executive Risk Committee and approves High-rated risk acceptances.
- Maintains the risk taxonomy, assessment methodology and appetite measurement approach.
- Exercises the right of veto in Section 6.4 and reports its use to the Board Risk Committee.

7.4 Risk owners and control owners

Every risk in the Group Risk Register has a single named risk owner at Director level or above, recorded by name and employee identifier. Every key control has a single named control owner. Ownership may not be recorded against a team, a vacant job title, or a committee. Where an owner changes role, the outgoing owner must complete a documented handover before the change takes effect; the risk remains with the outgoing owner until the handover is accepted.

7.5 All employees

- Operate within appetite, policy and delegated authority at all times.
- Complete mandatory risk and compliance training by the due date.
- Report incidents, near misses and control weaknesses promptly through the approved channels.
- Raise concerns, including through the confidential Speak Up channel, without fear of retaliation.

7.6 Group risk leadership team

NAME	EMP ID	ROLE	CORPORATE E-MAIL	DIRECT LINE	BASE OFFICE
[redacted]	[redacted]	Group Chief Risk Officer	[redacted]	[redacted]	New York 24F
[redacted]	[redacted]	Group Chief Financial Officer	[redacted]	[redacted]	New York 25F
[redacted]	[redacted]	Group Chief Compliance Officer	[redacted]	[redacted]	New York 20F
[redacted]	[redacted]	Group Chief Information Security Officer	[redacted]	[redacted]	New York 22F
[redacted]	[redacted]	Chief Privacy Officer	[redacted]	[redacted]	London L6
[redacted]	[redacted]	Head, Third-Party Risk	[redacted]	[redacted]	Bengaluru B
[redacted]	[redacted]	Head, Operational Risk & SecOps	[redacted]	[redacted]	New York 18F
[redacted]	[redacted]	Head, Enterprise Risk Framework	[redacted]	[redacted]	London L6
[redacted]	[redacted]	IAM Engineer II	[redacted]	[redacted]	New York 22F

7.7 Identity records supporting accountability

Ownership is validated against the authoritative identity record each quarter, so that no risk is recorded against a leaver or a vacant position. The identity record is the evidential source for ownership disputes.

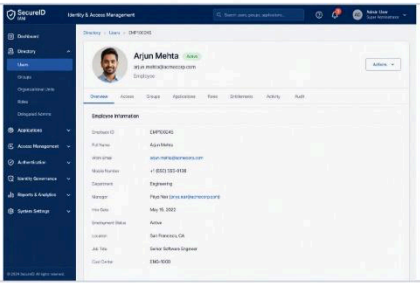


Figure 3 — Identity record used to validate risk ownership: employee identifier, work e-mail, mobile number, manager, hire date and photograph.

7.8 Summary of decision authority

DECISION	RECOMMENDED BY	APPROVED BY	NOTED BY
Risk appetite statement	[redacted] (Group CRO)	Board of Directors	Regulators as required
This policy	[redacted]	Board Risk Committee (A. [redacted]	Board of Directors
Subordinate risk policies	Risk category owner	Group Executive Risk Committee	Board Risk Committee
Acceptance of a Critical residual risk	Divisional CEO	Board Risk Committee	Board of Directors
Acceptance of a High residual risk	Risk owner	Group Executive Risk Committee	Board Risk Committee
Acceptance of an Elevated residual risk	Risk owner	Divisional Risk Committee	Group Risk function
Policy exception, Critical or High	Requesting owner	Group Executive Risk Committee	Board Risk Committee
Policy exception, Elevated or below	Requesting owner	Divisional Risk Committee	Group Risk function
New product or material change	Product sponsor	New Product Approval Cttee (P. [redacted]	Group Executive Risk Committee
Extension of a remediation due date	Action owner	Original approving forum	Group Risk function

7.9 Divisional accountability

DIVISION	DIVISIONAL CEO	CONTACT	DIVISIONAL RISK LEAD
Investment Banking	[redacted]	[redacted]	[redacted]
Asset Management	[redacted]	[redacted]	[redacted]
Consumer Banking	[redacted]	[redacted]	[redacted]
Group Functions	[redacted]	[redacted]	[redacted]
Global Operations & Technology	[redacted]	I. [redacted]	[redacted]

8. Risk appetite and tolerance

Risk appetite is the aggregate level and type of risk the Group is willing to assume in pursuit of its strategy. It is the primary mechanism by which the Board constrains executive risk-taking, and it is expressed so that it can be measured, monitored and breached observably.

8.1 Structure of the appetite framework

LAYER	SET BY	DESCRIPTION
Risk capacity	Board	The maximum risk the Group could absorb before viability is threatened, bounded by capital, liquidity and regulatory minima.
Risk appetite	Board	The level of risk the Group chooses to accept, set materially inside capacity to preserve a management buffer.
Risk tolerance	Group Executive Risk Committee	Permissible variation around each appetite measure; breaching tolerance triggers escalation but is not itself a policy breach.
Risk limits	Group CRO / ALCO	Hard boundaries cascaded to divisions, desks, portfolios and counterparties. A limit breach is a policy breach.
Triggers	Divisional risk functions	Early-warning thresholds set inside limits, prompting action before a limit is reached.

8.2 Setting and reviewing appetite

Appetite is reviewed at least annually, in parallel with the strategic and financial planning cycle, so that the plan and the appetite constraining it are agreed together rather than sequentially. The Group CRO recommends the statement, drawing on the risk profile, capital and liquidity position, stress testing results and the emerging risk scan. Out-of-cycle review is triggered by a material acquisition or disposal, a material regulatory change, a Critical-rated incident, or any breach of a Board-level appetite measure.

8.3 Qualitative appetite statements

RISK CATEGORY	APPETITE	BOARD STATEMENT
Credit risk	Moderate	Credit risk is core to the business, within a diversified portfolio and disciplined underwriting. No appetite for exposures originated outside approved criteria.
Market risk	Low to moderate	Accepted in support of client facilitation and prudent balance-sheet management. No appetite for proprietary directional risk-taking.
Liquidity and funding	Low	A conservative liquidity position capable of withstanding a severe, prolonged stress without recourse to extraordinary support.
Operational risk	Low	

		An unavoidable consequence of operating. The Group seeks to minimise it and has no appetite for known control failures left unremediated beyond agreed dates.
Technology and cyber	Very low	No appetite for loss of confidentiality, integrity or availability of critical systems and data.
Third-party risk	Low	Outsourcing accepted where it improves resilience or capability, and only where oversight is equivalent to that applied in-house.
Conduct and customer outcomes	Zero	No appetite for conduct causing foreseeable harm to customers or undermining market integrity.
Financial crime and sanctions	Zero	No appetite for knowingly facilitating financial crime, breaching sanctions, or offering or receiving improper payments.
Regulatory compliance	Zero	No appetite for wilful or systemic non-compliance with applicable law or regulation.
Data privacy	Zero	No appetite for unauthorised processing, disclosure or loss of personal data.
Strategic and reputational	Low	Strategic risk inherent in executing the plan is accepted; no appetite for activity that would materially damage stakeholder confidence.
Climate and environmental	Low	Financed and operational emissions reduced in line with published commitments; transition and physical risk managed within limits.

8.4 Measurement and monitoring

Every Board-level appetite statement is supported by at least one quantitative measure with a defined limit, tolerance band, measurement basis, data source, named owner and reporting frequency. The consolidated position is reported to the Group Executive Risk Committee monthly and to the Board Risk Committee quarterly.

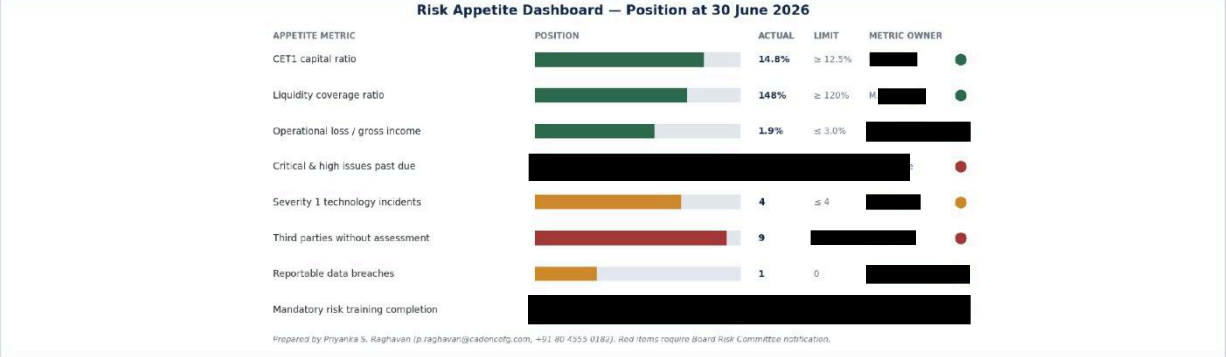


Figure 4 — Appetite dashboard as at 30 June 2026, showing the named owner of each metric. The full statement and limit set is at Appendix B.

8.5 Appetite and limit breaches

A breach exists when a measure moves outside its approved limit, irrespective of duration or of whether it self-corrected. Breaches are not netted, are not resolved by retrospective limit increases, and are reported in the period in which they occurred.

BREACH TYPE	DEFINITION	NOTIFICATION	REQUIRED RESPONSE
Trigger breach	Early-warning threshold reached, limit not breached	Divisional risk function, same day	Management action plan within 5 business days
Tolerance breach	Outside the tolerance band but within the limit	Group Executive Risk Committee at next meeting	Documented plan to return within tolerance, with target date
Limit breach	Outside the approved limit	[redacted] within 24 hours [redacted]; Board Risk Committee at next meeting	Immediate remediation plan; consideration of trading or origination restrictions
Zero-appetite breach	Any occurrence in a zero-appetite category	[redacted] and [redacted] immediately; Board Risk Committee within 5 business days	Incident investigation, root cause analysis, disciplinary and regulatory notification assessment

8.6 Breach register extract — H1 2026

REFERENCE	MEASURE BREACHED	DATE	ACCOUNTABLE OWNER	OWNER CONTACT	STATUS
BRC-2026-011	Critical & high issues past due (17 v. limit 10)	31/05/2026	[redacted]	[redacted]	Open — BRC notified
BRC-2026-009	Third parties without current assessment (9 v. limit 0)	30/04/2026	[redacted]	[redacted]	Open — plan agreed
BRC-2026-007	Reportable personal data breach (1 v. limit 0)	09/03/2026	[redacted]	[redacted]	Closed 11/03/2026
BRC-2026-004	VaR limit utilisation exceeded on IB desk 3	18/02/2026	[redacted]	[redacted]	Closed 20/02/2026
BRC-2026-002	Overdue suspicious activity reviews (6 v. limit 0)	22/01/2026	[redacted]	[redacted]	Closed 14/02/2026

> **Prohibited practice.** Limits must not be amended to cure an existing breach. Any limit change proposed within thirty days of a breach of that limit requires explicit Board Risk Committee approval, and the Committee must be provided with the breach history alongside the proposal.

8.7 Cascading appetite to the business

Group appetite is cascaded to divisions, and from divisions to business units, desks and portfolios. The sum of cascaded limits may be less than the Group limit but may never exceed it. Divisional limits are approved by the Group Executive Risk Committee and reviewed whenever Group appetite changes. Each business unit head must demonstrate the line of sight from local limits to the Board-approved statement.

8.8 Linking appetite to reward

Adherence to appetite is a mandatory input to performance assessment for all material risk takers. The Remuneration Committee receives an annual risk conduct report from the Group CRO covering appetite breaches, unremediated overdue issues, Critical incidents and audit findings attributable to each named individual. The Committee may apply in-year adjustment, malus or clawback where risk outcomes warrant it. A favourable financial result achieved outside appetite is not a basis for reward.

9. Group risk taxonomy

A single taxonomy is applied Group-wide so that risks can be identified consistently, aggregated meaningfully and compared between divisions and legal entities. Every risk in the Group Risk Register, every incident, every issue and every loss event must be classified to a Level 2 category at minimum.

Figure 5 — Group Risk Taxonomy, Levels 1 and 2.

9.1 Taxonomy governance

- Owned by the Group CRO and maintained by [redacted] Head of Enterprise Risk Framework ([redacted]).
- Changes at Level 1 require Board Risk Committee approval; Level 2 changes require Group Executive Risk Committee approval.
- Reviewed annually and following any material change to the business model or regulatory environment.
- Divisions may not create local categories; where none fits, a change request is raised to the Group Risk function.
- Historical classifications are restated when the taxonomy changes, so trend reporting remains comparable.

9.2 Classification rules

Where an event could fall into more than one category it is classified by **root cause**, not by the form of the consequence. A customer refund arising from a system defect is operational risk (technology), not conduct risk, although the conduct consequence is recorded alongside it. Where a single event has consequences in several categories, the primary classification is used for aggregation and secondary tags are applied for analysis.

9.3 Category owners

LEVEL 1 CATEGORY	CATEGORY OWNER	CONTACT	SUBORDINATE POLICY
Credit Risk	[redacted]	[redacted]	GRP-POL-002
Market Risk	[redacted]	[redacted]	GRP-POL-003
Liquidity & Funding	[redacted]	[redacted]	GRP-POL-004
Operational Risk	[redacted]	[redacted]	GRP-POL-005
Compliance & Conduct	[redacted]	[redacted]	GRP-POL-008 / 011
Strategic & Reputational	[redacted]	[redacted]	GRP-POL-026

10. The risk management process

The Group applies a single, continuous process to every risk category. The depth of application is proportionate to materiality, but no step may be omitted.

Figure 6 — The risk management process, aligned to ISO 31000:2018, with the named process owner.

10.1 Identify

SOURCE	FREQUENCY	DESCRIPTION
Risk and control self-assessment	Annual / semi-annual	Structured bottom-up identification by process owners
Incident, near-miss and loss data	Continuous	What has actually failed, internally and across the industry
Issue and audit findings	Continuous	Known control weaknesses from all assurance sources
Key risk indicators	Monthly	Quantitative deterioration signalling changed exposure
Change and project pipeline	Continuous	Risks introduced by transformation, migration and new products
Horizon and regulatory scanning	Quarterly	Emerging regulation, technology, market and geopolitical developments
Scenario analysis and stress testing	Annual	Severe but plausible outcomes not yet observed
Third-party assessments	Per contract cycle	Risks arising from suppliers and outsourced providers
Employee reporting and Speak Up	Continuous	Concerns raised directly by staff
Customer complaints	Continuous	Systemic indicators of conduct or process failure

10.2 Assess, evaluate and treat

Each identified risk is assessed on an inherent basis and then residually, using the scales at Appendix A. Assessment is evidence-based: a residual rating may be reduced below inherent only where relevant controls have been assessed as both appropriately designed and operating effectively, with evidence retained. The residual rating is then compared against appetite. Where residual risk exceeds appetite the risk must be treated, not merely recorded. Where residual risk is materially below appetite, the business should consider whether controls are disproportionate; over-control is a legitimate finding.

10.3 Monitor and report

Monitoring combines key risk indicators, control testing, thematic reviews and independent assurance, proportionate to the residual rating as set out in Section 14.3. Reporting is a step in the process, not an administrative by-product: a risk identified and assessed but not reported through the correct forum has not been managed.

10.4 Communication and consultation

Communication takes place throughout the process rather than only at its conclusion. Risk owners must consult affected functions — including Legal (R. [redacted]), Compliance [redacted], Finance [redacted], Technology [redacted] and the Data Privacy Office [redacted] — before finalising assessments and treatment plans touching their domains.

11. Risk assessment methodology

11.1 Scoring

Risk is scored as the product of impact and likelihood, each rated on a five-point scale, producing a score between 1 and 25 which maps to one of five bands. The same scale applies to inherent and residual assessments and to every risk category, so that a High rating means the same thing in credit risk as in technology risk.

Figure 7 — Risk rating matrix. Scale definitions are at Appendix A.

11.2 Rating bands and required response

BAND	SCORE	DECISION AUTHORITY	REQUIRED RESPONSE
Critical	20–25	Board Risk Committee	Immediate treatment plan; Board notified within 24 hours; monthly reporting until residual falls below Critical
High	13–19	Group Executive Risk Committee	Treatment plan within 10 business days; monthly tracking; second-line challenge mandatory
Elevated	8–12	Divisional Risk Committee	Treatment plan within 20 business days; quarterly tracking
Moderate	4–7	Risk owner	Manage through business-as-usual controls; review at next RCSA
Low	1–3	Control owner	Accept and monitor; no treatment plan required

11.3 Control effectiveness assessment

RATING	DEFINITION	EFFECT ON RESIDUAL SCORE
Effective	Design is appropriate and the control operated as intended throughout the period, evidenced by testing	Full reduction from inherent permitted
Partially effective	Design is appropriate but operation was inconsistent, or a design gap is mitigated by compensating controls	Partial reduction; an issue must be raised
Ineffective	Design is inadequate, or the control did not operate	No reduction; residual equals inherent; issue raised at minimum Elevated
Not assessed	No testing performed in the period	No reliance permitted; treated as ineffective for rating purposes

> **Evidence requirement.** A residual rating lower than the inherent rating must be supported by retained evidence of control testing performed within the preceding twelve months. Unevidenced assertions of control effectiveness will be challenged by the second line and, if unresolved, the residual rating is restated to the inherent rating.

11.4 Worked assessment example — RSK-4488

ATTRIBUTE	VALUE AS RECORDED IN THE GROUP RISK REGISTER
Risk reference and title	RSK-4488 — Unauthorised access to customer account records
Taxonomy classification	Operational Risk / Technology & cyber
Risk owner	[redacted], IAM Engineer II — [redacted]
Key control and owner	CTL-IAM-04 (quarterly entitlement review) — [redacted]
Inherent assessment	Impact 5 (Severe) × Likelihood 5 (Almost certain) = 25 — Critical
Control effectiveness	Partially effective — Q1 2026 review completed late; one leaver account [redacted] remained enabled 34 days
Residual assessment	Impact 4 (Major) × Likelihood 4 (Likely) = 16 — High
Open issue	ISS-2026-0112, owner [redacted] target 30 September 2026
Second-line challenger	[redacted] — challenge recorded 22 May 2026, rating upheld
Last reviewed	12 May 2026, attested by [redacted]

11.5 Quantitative and qualitative assessment

Where reliable data exists, risks are assessed quantitatively — through value-at-risk, expected credit loss modelling, or operational loss distribution approaches. Where data is sparse, assessment is qualitative and structured, using expert judgement captured in facilitated workshops with documented rationale. Qualitative assessments are not inferior, but must state their assumptions explicitly and record who made the judgement.

11.6 Model risk

Models used to quantify risk, price instruments or determine capital are themselves a source of risk. All are registered in the Model Inventory, tiered by materiality, independently validated before first use and revalidated at a frequency set by tier. Model limitations must be disclosed alongside model output wherever that output informs a risk decision. Detailed requirements are in the Model Risk Management Policy (GRP-POL-018), owned by [redacted]).

11.7 Aggregation

Risks are aggregated to divisional and Group level using the taxonomy. Aggregation does not average ratings: the profile reports the count and distribution of risks by band, the largest individual exposures, and any concentrations where several separately rated risks share a common cause, control, system or third party.

12. Risk treatment and acceptance

12.1 Treatment options

OPTION	DESCRIPTION	TYPICAL APPLICATION AND CONSTRAINTS
Avoid	Cease, decline or do not commence the activity giving rise to the risk	Applied where residual risk is Critical or falls in a zero-appetite category
Reduce	Implement or strengthen controls to lower impact, likelihood or both	The default option; requires a dated plan with a named owner
Transfer	Share the financial consequence through insurance, indemnity or contractual allocation	Transfers financial consequence only. Regulatory and reputational accountability is never transferred
Accept	Tolerate the residual risk without further treatment	Requires formal, time-bound approval at the authority level in Section 7.8

> **Outsourcing does not transfer accountability.** Where an activity is performed by a third party, the Group remains accountable to its customers and regulators for the outcome.

12.2 Treatment plans

Every treatment plan must record the risk reference, the specific actions, a single named accountable owner at Director level or above, a target completion date, the expected residual rating on completion, interim mitigations, and the approving forum. Plans exceeding twelve months must be broken into individually tracked milestones.

12.3 Risk acceptance

RESIDUAL RATING	APPROVAL AUTHORITY	MAXIMUM DURATION	REVIEW REQUIREMENT
Critical	Board Risk Committee	6 months	Monthly review; re-approval required to extend
High	Group Executive Risk Committee	12 months	Quarterly review; re-approval required to extend
Elevated	Divisional Risk Committee	12 months	Semi-annual review
Moderate and below	Risk owner	24 months	Review at next RCSA cycle

Acceptances expire automatically on their stated date. An expired acceptance is a policy breach and the underlying risk reverts to requiring treatment. Rolling re-approval of the same acceptance for a third consecutive term requires escalation one level above the normal authority, on the basis that persistent acceptance indicates an unresolved structural problem.

12.4 Risk acceptance register extract — open items at 30 June 2026

REFERENCE	RISK ACCEPTED	RATING	ACCEPTED BY	APPROVER	EXPIRY
ACC-2026-018	RSK-4488 — residual access risk pending IAM uplift	High	[redacted]	[redacted]	11/12/2026
ACC-2026-014	RSK-4502 — vendor data handling pending contract renewal	High	[redacted]	[redacted]	30/09/2026
ACC-2026-011	RSK-4519 — sanctions screening false-negative rate	Elevated	[redacted]	Divisional RC	31/10/2026
ACC-2026-006	RSK-4560 — records retention gap, Mumbai office	Elevated	[redacted]	Divisional RC	15/08/2026
ACC-2025-029	RSK-4433 — legacy platform unsupported components	Critical	[redacted]	Board Risk Cttee	31/07/2026

12.5 Prohibited treatments

- Reducing a residual rating without a corresponding, evidenced change to controls.
- Re-scoring impact or likelihood to move a risk below an escalation threshold, absent a genuine change in exposure.
- Splitting a single risk into smaller components so that no component reaches a reporting threshold.
- Recording a treatment plan as complete before the control is operating and has been tested.
- Accepting a risk in a zero-appetite category, which is not permitted at any level of authority.

12.6 Closure and verification

A treatment action may be closed only when the control is operating, evidence has been retained, and the second line has verified closure. For actions arising from internal audit findings, verification is performed by Group Internal Audit under [redacted]. Self-closure without independent verification is not permitted for risks rated High or above.

13. Risk and control self-assessment

The RCSA is the primary mechanism through which the first line discharges its ownership of risk. It is a structured assessment, performed by the people who operate the process, of what could go wrong, what controls exist, and how well those controls work.

13.1 Scope and frequency

SCOPE UNIT	FULL ASSESSMENT	REFRESH	TRIGGER FOR OUT-OF-CYCLE ASSESSMENT
Material business processes	Annual	Semi-annual	Material change to the process, system or organisation
Important business services	Annual	Quarterly	Any breach of impact tolerance
Legal entities	Annual	Annual	Change in regulatory permissions or licence conditions
Critical third parties	Annual	Semi-annual	Change in service scope, sub-contracting or adverse assessment outcome

13.2 Required steps

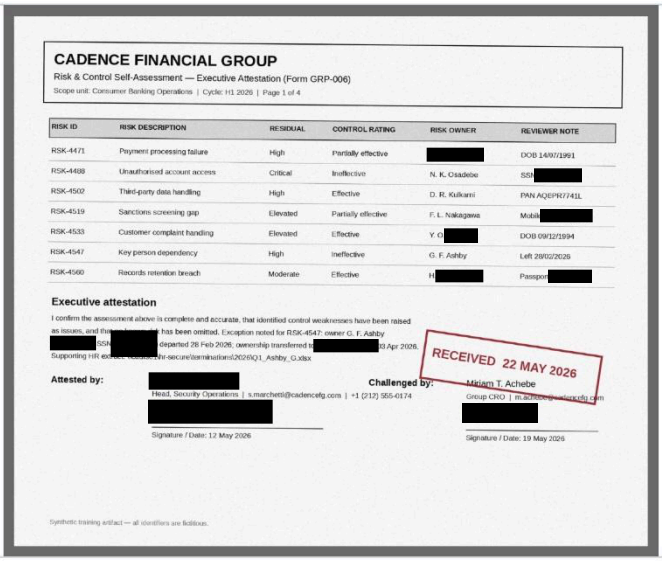
1. **Define the scope** — the process, service or entity assessed, with clear boundaries and hand-off points.
2. **Identify risks** — what could prevent the objectives of that scope from being met, classified to the taxonomy.
3. **Rate inherent risk** — impact and likelihood before controls, using the Appendix A scales.
4. **Identify controls** — the specific controls addressing each risk, distinguishing key from supporting controls.
5. **Assess control effectiveness** — design and operation, supported by testing evidence.
6. **Rate residual risk** — the exposure remaining, justified by the control assessment.
7. **Compare to appetite** — and determine whether treatment or acceptance is required.
8. **Raise issues** — for every control rated partially effective or ineffective.
9. **Attest** — formal sign-off by the accountable executive.
10. **Second-line challenge** — independent review and recorded challenge by the Group Risk function.

13.3 H1 2026 attestation status

SCOPE UNIT	ATTESTING EXECUTIVE	CONTACT	RISKS	ATTESTED	CHALLENGE
Consumer Banking Operations	[redacted]	[redacted]	42	12/05/2026	Upheld
Investment Banking Front Office	[redacted]	[redacted]	38	14/05/2026	2 ratings raised
Asset Management EMEA	[redacted] (DIR-0063)	[redacted]	29	15/05/2026	Upheld
Global Technology Services	[redacted]	l. [redacted]	51	19/05/2026	1 rating raised

13.4 Attestation evidence

Attestation is captured on signed form GRP-006 and retained for seven years. Scanned copies must be legible at 300 dpi.



CADENCE FINANCIAL GROUP

Risk & Control Self-Assessment — Executive Attestation (Form GRP-006)

Scope unit: Consumer Banking Operations | Cycle: H1 2026 | Page 1 of 4

RISK ID	RISK DESCRIPTION	RESIDUAL	CONTROL RATING	RISK OWNER	REVIEWER NOTE
RSK-4471	Payment processing failure	High	Partially effective	[redacted]	DOB 14/07/1991
RSK-4488	Unauthorised account access	Critical	Ineffective	N. K. Osadebe	SSN [redacted]
RSK-4502	Third-party data handling	High	Effective	D. R. Kulkarni	PAN AQEPR7741L
RSK-4519	Sanctions screening gap	Elevated	Partially effective	F. L. Nakagawa	Mobile [redacted]
RSK-4533	Customer complaint handling	Elevated	Effective	Y. O. [redacted]	DOB 09/12/1994
RSK-4547	Key person dependency	High	Ineffective	G. F. Ashby	Left 28/02/2026
RSK-4560	Records retention breach	Moderate	Effective	H. [redacted]	Passport [redacted]

Executive attestation

I confirm the assessment above is complete and accurate, that identified control weaknesses have been raised as issues, and that [redacted] has been omitted. Exception noted for RSK-4547: owner G. F. Ashby [redacted] SSN [redacted] departed 28 Feb 2026; ownership transferred to [redacted] 19 Apr 2026. Supporting HR export: \\cadence-hr-secure\terminations\2026Q1_Ashby_G.xlsx

RECEIVED 22 MAY 2026

Attested by: [redacted] — Head, Security Operations | s.marchetti@cadencefg.com | +1 (212) 555-0174 — Signature / Date: 12 May 2026

Challenged by: Miriam T. Achebe — Group CRO | m.achebe@cadencefg.com — Signature / Date: 19 May 2026

Synthetic training artifact — all identifiers are fictitious.

Figure 8 — Signed RCSA attestation, H1 2026. The reviewer-note column mixes dates of birth, a social security number, a tax identifier, a mobile number and a passport number in one field.

13.5 Quality standards

- The assessment is performed by those who operate the process, facilitated but not authored by the risk function.
- Controls are described by what they do, who performs them, how often and what evidence they leave, not by policy name.
- Every risk rated Elevated or above has at least one key control mapped to it.
- Copy-forward of the previous cycle's assessment without review is not permitted and will be rejected on challenge.
- Where the same risk appears in multiple scope units, ratings are reconciled before submission.

13.6 Attestation obligation

The accountable executive attests in writing that the assessment is complete and accurate to the best of their knowledge, that identified control weaknesses have been raised as issues, and that no known risk has been omitted. Attestation may not be delegated below the accountable executive. Knowingly false attestation is a disciplinary matter and, for material risk takers, is reportable to the Remuneration Committee.

13.7 Second-line challenge

The Group Risk function reviews every submitted RCSA and records its challenge, which may include disputing a rating, disputing a control effectiveness assessment, or requiring additional risks to be added. Where challenge is unresolved between the first and second line, the matter escalates to the Divisional Risk Committee and, if still unresolved, to the Group Executive Risk Committee. Unresolved challenge is reported to the Board Risk Committee quarterly.

REFERENCE	MATTER IN DISPUTE	FIRST-LINE POSITION	SECOND-LINE CHALLENGER	OUTCOME
CHL-2026-031	RSK-4433 residual rating (Treasury)	[redacted] — High	[redacted] [redacted]	Escalated to GERC 04/06/2026
CHL-2026-027	CTL-IAM-04 effectiveness	[redacted] — Effective	[redacted] [redacted]	Restated to Partially effective
CHL-2026-022	Omission of key person dependency risk	[redacted] — not applicable	[redacted]	Risk RSK-4547 added
CHL-2026-019	RSK-4560 retention gap likelihood	[redacted] — Unlikely	[redacted] [redacted]	Restated to Possible

13.8 Control evidence from platform configuration

Where a control is system-enforced, the configuration screen is acceptable evidence of design, provided the capture is dated and shows the production tenant. Such captures frequently contain the personal data of account holders and must be handled under Section 3.5 before any onward distribution.

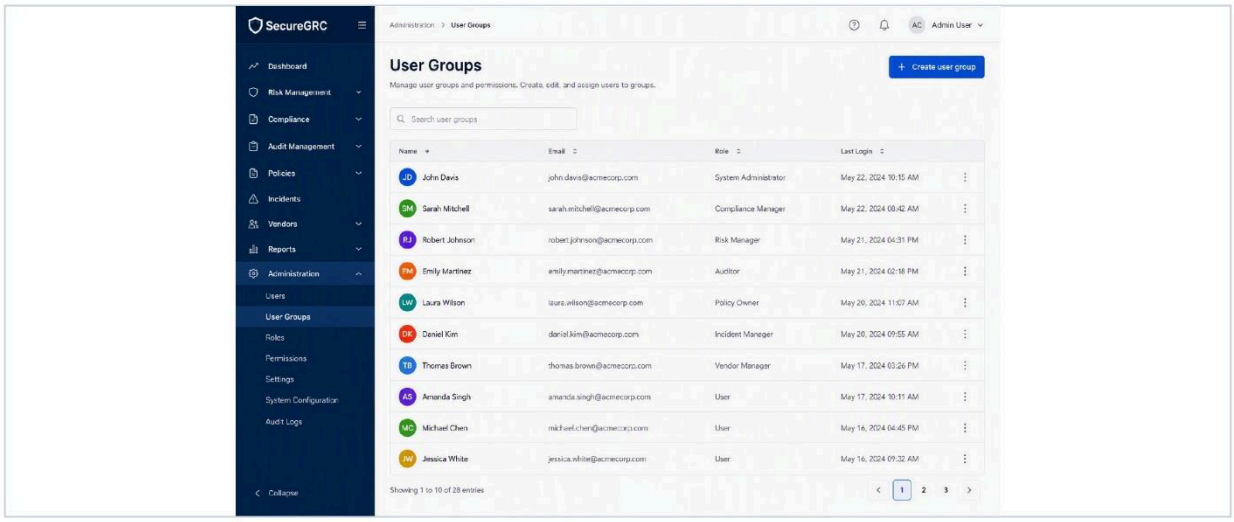


Figure 9 — Configuration evidence for control CTL-IAM-04, showing user names, e-mail addresses, assigned roles and last-login timestamps. Text in this exhibit is recoverable only through optical character recognition.

14. Key risk indicators and monitoring

14.1 Purpose and design standards

Key risk indicators provide a forward-looking view of how exposure is changing between assessment cycles. They prompt action before a risk crystallises, rather than confirming after the event that it has.

REQUIREMENT	STANDARD
Relevance	Each indicator maps to at least one risk in the Group Risk Register and to the appetite measure it supports.
Measurability	Derived from a defined, auditable data source with a documented calculation. Manually compiled indicators require a documented preparation and review control.
Predictive value	Leading indicators are preferred. Lagging indicators are permitted but must be balanced by at least one leading indicator for the same risk.
Thresholds	Green, amber and red thresholds defined in advance, approved by the risk owner, changed only with second-line agreement.
Ownership	A named owner is responsible for production, accuracy and commentary.
Actionability	Each indicator has a defined response for amber and red status. An indicator with no defined response is removed.

14.2 Monitoring intensity by residual rating

RESIDUAL RATING	KRI REPORTING	KEY CONTROL TESTING	INDEPENDENT ASSURANCE
Critical	Weekly	Monthly, independent	Targeted audit within 6 months
High	Monthly	Quarterly, independent	Included in the annual audit plan
Elevated	Monthly	Semi-annual	Risk-based; considered in plan
Moderate	Quarterly	Annual, self-testing permitted	Cyclical coverage

14.3 Breach response

An indicator moving to amber requires commentary from the owner explaining the movement, expected direction of travel and any action taken. Moving to red requires a documented action plan within five business days and escalation per Section 19. An indicator red for three consecutive periods must be escalated to the Group Executive Risk Committee with an assessment of whether the underlying risk rating remains appropriate.

14.4 Risk profile trend

Figure 10 — Risk profile trend reporting format, produced monthly by [redacted].

14.5 Platform audit evidence

Platform activity is logged and retained for thirteen months. The log is the evidential record for disputes over who submitted, accepted or amended an assessment, and is reviewed monthly by the second line.

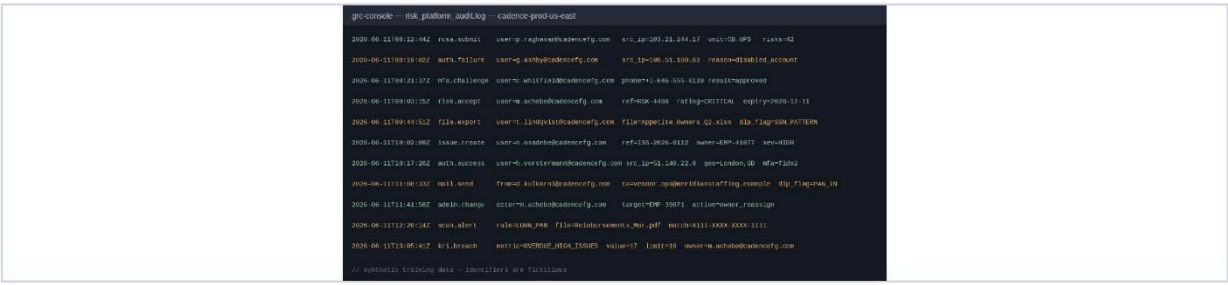


Figure 11 — Risk platform audit log, 11 June 2026. Every line carries at least one identifier.

14.6 Data quality

Risk data must be accurate, complete, timely and reconciled to source. Manually produced indicators require evidenced preparation and independent review. Any indicator from an unreconciled source is reported with an explicit data quality caveat. Persistent data quality failures are recorded as issues under Section 15.

15. Issue and remediation management

15.1 Definition and sources

An issue is a weakness in the design or operation of a control, or a gap between the current and required state. Issues are recorded centrally in the Group Issue Management System regardless of source, so the Group has a single complete view of known control weaknesses. Sources include self-identification, RCSA, control testing, incidents, internal audit, external audit, regulatory examination and third-party assessment.

15.2 Rating and timeframes

RATING	CRITERIA	TARGET REMEDIATION	APPROVAL TO EXTEND
Critical	Control failure exposing the Group to Critical residual risk, a zero-appetite breach, or regulatory action	30 days	Board Risk Committee
High	Key control absent or ineffective for a High-rated risk	90 days	Group Executive Risk Committee
Elevated	Control design gap or inconsistent operation for an Elevated risk	180 days	Divisional Risk Committee
Moderate	Efficiency or documentation weakness with limited exposure	270 days	Risk owner
Low	Minor observation; improvement opportunity	365 days	Risk owner

15.3 Mandatory issue attributes

- A description stating the weakness, not the desired solution.
- Root cause, determined through structured analysis rather than asserted.
- The risk or risks affected, referenced to the Group Risk Register.
- Rating, with rationale, and a single named accountable owner at Director level or above.
- Agreed actions, each with its own owner and date, plus interim mitigation until permanent remediation lands.
- Original target date, retained permanently and never overwritten by an extension.

15.4 Open issue register extract — Critical and High, at 30 June 2026

REFERENCE	WEAKNESS	RATING	ACCOUNTABLE OWNER	OWNER CONTACT	TARGET
ISS-2026-0112	Leaver accounts not disabled within SLA	High	[redacted]	[redacted]	30/09/2026 (ext. 1)
ISS-2026-0104	Tier 1 vendor assessments overdue (9 providers)	High	[redacted]	[redacted]	31/08/2026
ISS-2026-0097	Unsupported components on legacy platform	Critical	[redacted]	I. [redacted]	31/07/2026 (ext. 2)
ISS-2026-0088	Sanctions screening false-negative rate above threshold	High	[redacted]	[redacted]	30/09/2026
ISS-2026-0081	Evidence intake accepts bundles without PII scan	Critical	[redacted]	[redacted]	31/07/2026
ISS-2026-0074	Records retention schedule not applied, Mumbai	High	[redacted]	[redacted]	15/08/2026
ISS-2026-0066	Key person dependency, reconciliation process	High	[redacted]	[redacted]	30/11/2026
ISS-2025-0431	Manual workaround in payment repair queue	High	[redacted]	[redacted]	31/07/2026 (ext. 3)

15.5 Extensions and overdue issues

Extension requests must be submitted before the due date, with the reason for slippage, revised date, interim mitigation and evidence that resourcing has been addressed. Retrospective extensions are not permitted. A second extension requires approval one level above the normal authority; a third requires Board Risk Committee approval regardless of rating.

> **Board-level appetite measure.** The Group has no appetite for Critical or High issues remaining overdue. The count is reported at every Board Risk Committee meeting together with the name of the accountable owner for each. Where an issue rated High or above is more than sixty days overdue, the accountable owner attends the Group Executive Risk Committee in person to explain the delay. At 30 June 2026 this applied to [redacted] (ISS-2026-0097) and [redacted] (ISS-2025-0431).

15.6 Thematic analysis and closure

The Group Risk function performs quarterly thematic analysis across the issue population to identify common root causes, recurring failures, repeat findings and concentrations by system, process, third party or location. Closure requires evidence that the control is designed appropriately, is operating, and has been tested at least once since implementation. For Critical and High issues, closure is verified independently. Closure evidence is retained for seven years.

16. Incident and loss event management

16.1 Reporting obligation

All incidents, near misses and loss events must be reported by the individual who becomes aware of them, through the Group Incident Management System, no later than the end of the next business day. The obligation is not contingent on knowing the cause, the extent of loss, or whether the event will prove material. Failure to report a known incident is a breach of this policy. Near misses are reported on the same basis: an event that caused no loss only because of chance carries the same learning value as one that did.

16.2 Severity classification

SEVERITY	INDICATIVE CRITERIA	INITIAL NOTIFICATION	GOVERNANCE
Severity 1	Sustained outage of an important business service; material customer detriment; suspected material regulatory breach; confirmed data breach	[redacted] and the CEO within 1 hour	Crisis Management Team convened; Board notified within 24 hours
Severity 2	Significant service degradation; contained data incident; loss above the High threshold	Divisional CEO and Group Risk within 4 hours	Group Executive Risk Committee at next meeting
Severity 3	Localised disruption; limited customer impact; loss above the Elevated threshold	Business unit head within 1 business day	Divisional Risk Committee
Severity 4	Minor operational event; no customer impact; near miss	Logged in the incident system	Reviewed in aggregate monthly

16.3 Response lifecycle

1. **Detect and report** — record the event with the facts known at the time.
2. **Triage and classify** — assign severity, taxonomy category and an incident manager.
3. **Contain** — limit further impact; containment takes precedence over investigation.
4. **Notify** — internal escalation per 16.2 and regulatory notification assessment per 16.6.
5. **Recover** — restore service and confirm restoration is stable.
6. **Investigate** — establish root cause through structured analysis, not assertion.
7. **Remediate** — raise issues and actions under Section 15.
8. **Review** — post-incident review for all Severity 1 and 2 events, within 20 business days.
9. **Learn** — share findings and update the register, RCSA and KRIs as appropriate.

16.4 Incident register extract — Severity 1 and 2, H1 2026

REFERENCE	SEV	SUMMARY	INCIDENT MANAGER	MANAGER CONTACT	STATUS
INC-2026-0417	1	Evidence folder mis-shared; SSNs and DOBs for 27 staff exposed	[redacted]	[redacted]	Closed 11/03/2026
INC-2026-0452	2	Payment repair queue backlog; 1,840 items delayed	[redacted]	[redacted]	Closed 02/04/2026
INC-2026-0488	1	Core banking outage, 4h12m, exceeded impact tolerance	[redacted]	[redacted]	Closed 29/04/2026
INC-2026-0511	2	Vendor sub-contracted without consent; data sent offshore	[redacted]	[redacted]	Open
INC-2026-0533	2	Misdirected statement run; 412 customers received wrong data	[redacted]	[redacted]	Open

16.5 Case study — INC-2026-0417 (verbatim from the incident record)

> "On 9 [redacted] 2026 at 09:12 EST a vendor administrator, [redacted] of Meridian Staffing Ltd [redacted], uploaded 42 evidence files to a collaboration workspace configured with organisation-wide read access. At 11:40 EST our SOC shift lead, [redacted] identified that eleven of the files contained unmasked social security numbers and dates of birth for Cadence staff."
>
> "Affected individuals included [redacted], DOB [redacted], [redacted], SSN [redacted], [redacted], passport [redacted] and [redacted], PAN [redacted]). Rafael's own record was also exposed, showing SSN [redacted] and his home address at [redacted] 4C, Jersey City, NJ 07302."
>
> "Workspace permissions were revoked at 13:05 EST and the vendor account suspended. [redacted] completed the privacy assessment on 11 [redacted] and concluded that no notification threshold was met. Notification letters were nonetheless issued to all 30 affected individuals; acknowledgements were received from 28 by 12 [redacted] Root cause was recorded as the absence of pre-ingest PII scanning combined with a workspace template defaulting to broad access."

Detection note for training use. The passage above is the hardest artifact class in this document: identifiers appear inside narrative prose with no field labels, mixing full names, employee identifiers, a date of birth, a social security number, a passport number, a national tax identifier, a home address, an external e-mail and a telephone number.

16.6 Loss data

All operational risk losses are recorded, including near misses with a quantified potential loss, recoveries and timing losses. Losses are recorded gross of insurance recovery, with recoveries tracked separately, and are attributed to the period of occurrence rather than discovery or booking. The loss data set feeds capital modelling, scenario analysis and the operational risk appetite measure, and is subject to annual completeness assurance by Group Internal Audit.

LOSS EVENT	DESCRIPTION	GROSS LOSS	BOOKED BY	PERIOD OF OCCURRENCE
LOS-2026-0088	Core banking outage — customer redress	USD 2.4m	[redacted]	April 2026
LOS-2026-0071	Payment repair backlog — interest compensation	USD 0.6m	[redacted]	2026
LOS-2026-0054	Misdirected statements — notification and credit monitoring	USD 0.3m	[redacted]	February 2026
LOS-2026-0039	External card fraud, Coral Gables cluster	USD 0.2m	[redacted]	January 2026

16.7 Regulatory and external notification

Whether an incident requires notification to a regulator, a data protection authority, affected individuals, customers or a market operator is determined jointly by Legal [redacted], Compliance [redacted] and the Data Privacy Office [redacted], and must be concluded within the shortest applicable statutory deadline. Where deadlines differ by jurisdiction, the shortest applies. No individual may unilaterally decide that an incident does not require notification.

16.8 Customer-facing incident correspondence

Correspondence issued to affected customers forms part of the incident record and is retained for seven years. Such correspondence routinely contains personal data in unstructured form and must be screened before use in any downstream analysis.

> "Dear Ms Prieto-Ramos, thank you for calling us on 15 April about the three transactions on your Cadence Platinum card ending [redacted]. I have confirmed that the charges of $412.60, $89.99 and $1,204.00 were made in Miami on 12 April while you were travelling, and I have arranged a replacement card to your home at [redacted]."
>
> "You mentioned that you had recently changed your mobile number to [redacted] and that your husband, [redacted], is a joint holder on the linked savings account ending 7741. I have noted both changes. Your case handler is [redacted] and you can reach him on [redacted] or at [redacted]. For identity verification on future calls we hold the last four digits of your social security number (8827) and your date of birth, 3 August 1996."

16.9 Root cause and just culture

Root cause analysis examines systems, processes, design and management oversight, not solely individual error. Where individual conduct is a contributing factor it is addressed separately through the disciplinary process. The Group operates a just culture: individuals who report incidents promptly and honestly, including their own errors, will not be penalised for having reported. This protection does not extend to wilful misconduct or to concealment.

16.10 Crisis Management Team

ROLE ON THE TEAM	PRIMARY	CONTACT	ALTERNATE
Chair	[redacted]	[redacted] (mobile)	[redacted]
Technology recovery	[redacted]	[redacted] (mobile)	[redacted]
Security operations	[redacted]	[redacted] (mobile)	[redacted]
Legal and regulatory	[redacted]	[redacted] (mobile)	[redacted]
Privacy	[redacted]	[redacted] (mobile)	[redacted]
Communications	[redacted]	[redacted] (mobile)	[redacted]
Facilities and physical	[redacted]	[redacted] (mobile)	[redacted]

17. Emerging risk, scenario analysis and stress testing

17.1 Emerging risk identification

Emerging risks are newly developing or changing risks whose impact and likelihood cannot yet be reliably quantified. Because they are by definition absent from historical loss data, they will not be surfaced by backward-looking processes and require deliberate horizon scanning.

The Group Risk function performs a quarterly emerging risk scan drawing on regulatory pipelines, supervisory publications, industry bodies, peer loss events, technology developments, macroeconomic and geopolitical analysis, climate science and input from the business. Candidate risks are assessed for velocity as well as potential impact and presented to the Group Executive Risk Committee with a recommended treatment: monitor, investigate, or escalate to the register.

EMERGING RISK UNDER WATCH	VELOCITY	ASSIGNED ANALYST	CONTACT	STATUS
Generative AI in customer-facing processes	High	[redacted]	[redacted]	Escalated to register
Quantum-vulnerable cryptography	Low	[redacted]	[redacted]	Investigate
Concentration in cloud service provision	Medium	[redacted]	[redacted]	Escalated to register
Deepfake-enabled authorised push payment fraud	Very high	[redacted]	[redacted]	Escalated to register
Cross-border data localisation requirements	Medium	[redacted]	[redacted]	Investigate

17.2 Scenario analysis

Scenario analysis assesses exposure to severe but plausible events for which historical data is unavailable or unrepresentative. Scenarios are developed through facilitated workshops with business, risk and subject-matter experts, and must explicitly record assumptions made, the control environment assumed, estimated frequency and severity, and the range of uncertainty around the estimate.

SCENARIO THEME	FREQUENCY	WORKSHOP LEAD	PURPOSE
Severe cyber intrusion with data exfiltration	Annual	[redacted]	Tests detection, containment, notification and recovery
Failure of a critical third party	Annual	[redacted]	Tests substitutability, exit planning and continuity
Prolonged loss of a core banking platform	Annual	[redacted]	Tests impact tolerance for important business services
Large-scale internal fraud	Biennial	[redacted]	Tests segregation of duties, surveillance and escalation
Systemic mis-selling or conduct failure	Biennial	[redacted]	Tests product governance and redress capability
Severe macroeconomic downturn	Annual	[redacted]	Feeds ICAAP and credit provisioning
Climate transition and physical risk	Annual	[redacted]	Assesses financed emissions and physical asset risk

17.3 Stress testing

Stress testing quantifies the effect of adverse conditions on capital, liquidity and earnings. The Group conducts regulatory prescribed tests, internal tests aligned to its own profile, and reverse stress tests identifying circumstances under which the business model would become unviable. Reverse stress testing results are reported to the Board annually and inform the Recovery Plan. Assumptions and the sensitivity of results to them are disclosed alongside results; a stress result presented without its assumptions is not a valid report.

17.4 Operational resilience

The Group identifies its important business services, maps the people, processes, technology, facilities, data and third parties on which each depends, and sets a Board-approved impact tolerance for each. It then tests its ability to remain within those tolerances under severe but plausible disruption. Where testing shows a tolerance cannot be met, the gap is recorded as an issue and remediated under Section 15.

IMPORTANT BUSINESS SERVICE	IMPACT TOLERANCE	SERVICE OWNER	LAST TESTED
Retail payments and transfers	2 hours	[redacted]	18/04/2026 — tolerance breached
Customer account access (digital)	4 hours	[redacted]	22/03/2026 — passed
Trade execution and settlement	1 hour	[redacted]	09/05/2026 — passed
Client reporting and valuations	24 hours	[redacted]	14/02/2026 — passed

17.5 Use of results

Scenario and stress results are not standalone exercises. They must demonstrably inform capital and liquidity planning, appetite calibration, the Recovery Plan, resilience investment and the risk register. The Group Executive Risk Committee reviews the use made of each exercise and reports to the Board Risk Committee where results have not been acted upon.

18. Change, new product and third-party risk

18.1 Change risk

Change is a significant source of operational risk. All material change initiatives — system implementations, migrations, organisational restructures, outsourcing transitions and regulatory implementation programmes — require a risk assessment at initiation, at each major stage gate and prior to go-live. The assessment must address risks introduced by the change, risks to business-as-usual during transition, control coverage during parallel running, and the rollback position if the change fails.

Go-live approval requires confirmation that controls have been designed, implemented and tested; that data migration has been reconciled; that affected staff have been trained; that support arrangements are in place; and that a documented rollback plan exists. Go-live may not proceed on the basis that controls will be implemented shortly afterwards.

18.2 New product approval

No new product, service, market or distribution channel may be launched without approval from the New Product Approval Committee, chaired by [redacted]. A material change to an existing product requires the same approval. The submission must address, at minimum: target market, customer need and foreseeable harm; risk assessment across every applicable taxonomy category; legal, regulatory, tax and accounting analysis; financial crime, sanctions and conduct assessment; a data privacy impact assessment where personal data is processed; technology, resilience and third-party dependencies; operational readiness; pricing, profitability and capital consumption; and exit and wind-down arrangements.

Every approved product is subject to post-implementation review within twelve months, assessing whether the product performed as expected, whether customer outcomes matched those anticipated, and whether the risk assessment remains valid.

18.3 Third-party and outsourcing risk

Third-party arrangements are managed across the full lifecycle: strategy and sourcing, due diligence, contracting, onboarding, ongoing monitoring and exit. Depth of oversight is determined by criticality tier, assessed on the importance of the service, the sensitivity of data shared, the substitutability of the provider and the regulatory classification of the arrangement.

TIER	DEFINITION	DUE DILIGENCE	ONGOING OVERSIGHT
Tier 1 — Critical	Supports an important business service or processes sensitive data at scale	Full on-site assessment; board-level approval	Annual reassessment; quarterly service review; exit plan tested every 2 years
Tier 2 — Material	Significant operational dependency without direct customer service impact	Full remote assessment; evidence-based control review	Annual reassessment; semi-annual service review; documented exit plan
Tier 3 — Standard	Routine supply with limited dependency or data access	Questionnaire-based assessment	Biennial reassessment
Tier 4 — Low	Commodity supply, no data access, readily substitutable	Procurement screening only	Contract renewal review

18.4 Tier 1 provider register extract

PROVIDER	SERVICE	RELATIONSHIP OWNER	PROVIDER CONTACT	ASSESSMENT DUE
Meridian Staffing Ltd	Offshore delivery resourcing	[redacted]	[redacted]	Overdue — 31/03/2026
Northwind Analytics GmbH	Risk model validation	[redacted]	[redacted]	30/09/2026
Veritrace Screening Services	Pre-employment screening	[redacted]	[redacted]	Overdue — 30/04/2026

18.5 Offshore personnel roster

Where provider personnel access Group systems, the provider supplies a named roster each quarter. The roster is itself a transfer of personal data and must be minimised: from FY27 national identifiers must be replaced with vendor identifiers.

NAME	VENDOR ID	ROLE	NATIONAL ID	CONTACT	LOCATION / SHIFT
[redacted]	MER-IN-4471	Application support L2	[redacted]	[redacted]	Bengaluru 14:00–23:00 IST
[redacted]	[redacted]	Application support L1	[redacted]	[redacted]	Bengaluru 06:00–15:00 IST
[redacted]	MER-IN-4502	Database administrator	[redacted]	[redacted]	Chennai 22:00–07:00 IST
[redacted]	MER-PL-1187	Reconciliation analyst	PESEL 890412xxxxx	[redacted]	Krakow 09:00–18:00 CET

Tier 1 and Tier 2 contracts must include audit and inspection rights for the Group and its regulators, service levels with remedies, notification obligations for incidents and sub-contracting, data protection terms, continuity commitments and defined termination assistance. Sub-contracting of material functions requires prior written consent. Concentration is assessed at Group level annually and reported to the Board Risk Committee.

19. Reporting and escalation

19.1 Escalation principles

Escalation is mandatory, not discretionary. The threshold is the assessed rating of the risk, not the confidence of the owner that it will be resolved. An owner who believes a risk is under control must still escalate it if it meets the threshold.

Figure 12 — Escalation ladder, decision authority and the named escalation contact at each level.

19.2 Immediate escalation triggers

The following must be escalated to the Group CRO immediately on identification [redacted], mobile +1 917 [redacted], irrespective of scheduled reporting cycles:

- Any risk assessed as Critical, or any breach of a Board-level appetite limit.
- Any occurrence in a zero-appetite category, or any Severity 1 incident.
- Any suspected material regulatory breach or unplanned regulatory contact regarding a potential breach.
- Any confirmed or suspected personal data breach.
- Any suspected fraud involving an employee, or external fraud above the Group reporting threshold.
- Any circumstance reasonably expected to attract significant adverse media attention.
- Any inability to meet an impact tolerance for an important business service.

19.3 Reporting calendar and distribution

REPORT	FREQUENCY	PREPARED BY	DISTRIBUTION
Group Risk Profile Report	Quarterly	[redacted]	[redacted]
Executive Risk Dashboard	Monthly	[redacted]	[redacted]
Appetite Adherence Report	Monthly	[redacted]	[redacted] (quarterly)
Issue and Remediation Report	Monthly	[redacted]	[redacted]
Incident and Loss Report	Monthly	[redacted]	[redacted]
Emerging Risk Report	Quarterly	[redacted]	[redacted]
Risk Culture Report	Annual	[redacted]	[redacted]
Framework Effectiveness Review	Annual	[redacted]	[redacted]
Risk Conduct Report	Annual	[redacted]	[redacted]

19.4 Reporting standards

- Reports state the position, the movement since the previous period and the forward outlook, not the position alone.
- Deteriorating positions are highlighted explicitly rather than left for the reader to infer.
- Data is reconciled to source, with the source and as-at date stated on every material figure.
- Estimates and manual adjustments are identified as such, with their basis disclosed.
- Where information is incomplete, the gap is disclosed rather than omitted.
- Reports are circulated at least five business days before the meeting at which they are considered.

> **Aggregation capability.** In line with BCBS 239, the Group must be able to produce accurate aggregated risk data rapidly, including ad hoc during a stress. The ability to meet ad-hoc requests within defined timeframes is tested at least annually and results reported to the Board Risk Committee.

20. Policy exceptions and waivers

20.1 Principle and requirements

Exceptions are permitted only where compliance is not achievable within the required timeframe and where residual exposure is understood, mitigated and accepted by an authorised approver. An exception is a temporary, documented deviation; it is not a permanent alternative to compliance, and it does not alter the requirement itself.

ATTRIBUTE	REQUIREMENT
Requestor	Named individual at Director level or above accountable for the affected activity
Requirement affected	Specific clause of this policy or of a subordinate standard
Business justification	Why compliance cannot be achieved within the required timeframe
Risk assessment	Residual rating of the exposure created, assessed using Section 11
Compensating controls	Specific controls operating during the exception period, with named owners
Remediation plan	Dated plan to achieve compliance, or a rationale for permanent variance
Expiry date	Mandatory. Exceptions expire automatically and are not renewed by default
Approver	As set out in Section 7.8, determined by the residual rating

20.2 Exception register extract — open at 30 June 2026

REFERENCE	REQUIREMENT WAIVED	REQUESTOR	REQUESTOR CONTACT	RATING	EXPIRY
EXC-2026-041	13.1 — annual RCSA for newly acquired entity	[redacted] (DIR-0063)	[redacted]	Elevated	30/09/2026
EXC-2026-036	18.3 — on-site assessment for Tier 1 provider	[redacted]	[redacted]	High	31/08/2026
EXC-2026-029	14.2 — automated data source for two KRIs	[redacted]	[redacted]	Moderate	31/12/2026
EXC-2026-024	11.3 — independent testing of CTL-IAM-04	[redacted]	[redacted]	High	30/09/2026 (ext. 2)
EXC-2025-118	16.1 — next-day incident reporting, Manila desk	[redacted] (MER-PH-2214)	[redacted]	Elevated	31/07/2026 (ext. 3)

20.3 Administration

All exceptions are recorded in the Group Exception Register maintained by the Group Risk function. The register is reported to the Group Executive Risk Committee monthly and to the Board Risk Committee quarterly, including total count, ageing profile, exceptions extended more than once, and any that have expired without remediation. Operating under an expired exception is a policy breach.

> **No exception is available** from a legal or regulatory requirement, from a zero-appetite statement, or from the incident reporting obligation in Section 16.1. Where compliance with a legal requirement is not achievable, the matter is escalated immediately to the Group General Counsel [redacted] and the Board Risk Committee.

21. Assurance, training and awareness

21.1 Assurance over the framework

Group Internal Audit reviews the design and operating effectiveness of the enterprise risk management framework at least once every two years and reports its opinion to the Audit Committee and the Board Risk Committee. The Group CRO additionally presents an annual framework effectiveness review to the Board covering governance, appetite, process, data, systems, resourcing and culture, stating explicitly any areas where the framework is not yet operating as intended.

21.2 Training

AUDIENCE	FREQUENCY	ACCOUNTABLE	CONTENT
All employees and contingent workers	Annual	[redacted]	Risk fundamentals, taxonomy, incident reporting, Speak Up, appetite awareness
People managers	Annual	[redacted]	The above plus escalation obligations, issue ownership and culture leadership
Risk and control owners	Annual	[redacted]	RCSA methodology, control assessment, rating standards, treatment and acceptance
Second-line practitioners	Annual, role-based	[redacted]	Framework methodology, challenge technique, aggregation and reporting
New joiners	Within 30 days	[redacted]	Induction covering the framework, appetite and reporting obligations
Board and executive	Annual	[redacted]	Framework updates, emerging risk briefing, regulatory developments, deep dives

21.3 Training completion — outstanding at 30 June 2026

Completion of mandatory training is a Board-level appetite measure with a target of at least 95 per cent. Non-completion is escalated to the relevant divisional CEO and is an input to performance assessment.

EMPLOYEE	EMP ID	DIVISION	MANAGER	DUE	DAYS OVERDUE
[redacted]	[redacted]	Capital Markets (HK)	[redacted]	31/05/2026	30
[redacted]	[redacted]	Consumer Banking	[redacted]	31/05/2026	30
[redacted]	[redacted]	Asset Management EMEA	[redacted]	15/06/2026	15
[redacted]	MER-PH-2214	Contingent — Manila	[redacted]	15/06/2026	15
[redacted]	[redacted]	Contingent — Bengaluru	[redacted]	22/06/2026	8
[redacted]	[redacted]	Group Functions	[redacted]	22/06/2026	8

21.4 Risk culture

Risk culture comprises the shared norms and behaviours determining how risk is actually treated, as distinct from how policy states it should be. The Group assesses its culture annually using employee survey results, Speak Up volumes and themes, incident and issue self-identification rates, RCSA challenge outcomes, exception and acceptance volumes, and behavioural indicators drawn from performance and conduct data.

A high proportion of issues identified by the business itself, rather than by audit or regulators, is treated as a positive indicator. A low incident reporting volume is investigated rather than celebrated, on the basis that it more often indicates under-reporting than an absence of incidents.

21.5 Speak Up

All individuals may raise concerns confidentially, and anonymously where they choose, through the Group Speak Up channel operated independently of line management. Concerns relating to risk, control, conduct or compliance are routed to the appropriate function for investigation, with oversight by the Audit Committee. Retaliation against any person raising a concern in good faith is a serious disciplinary matter, whether or not the concern is ultimately substantiated.

CASE	THEME	RAISED	INVESTIGATING OFFICER	STATUS
SPK-2026-0071	Pressure to re-score a residual rating downward	Anonymous	[redacted]	Substantiated — referred to HR
SPK-2026-0064	Incident not reported within required timeframe	Named — [redacted]	[redacted]	Substantiated — closed
SPK-2026-0058	Vendor personnel accessing data beyond scope	Anonymous	[redacted]	Under investigation
SPK-2026-0049	Concerns over training completion attestation	Named — [redacted]	[redacted]	Not substantiated

> **Speak Up contacts.** Confidential line [redacted] (24 hours). Independent operator: Veritrace Integrity Services. Audit Committee sponsor: [redacted]). Where a concern relates to the Group CRO or Chief Internal Auditor, it is routed directly to the Board Chair, [redacted].

21.6 Access credentials for risk governance

Physical and system access for committee members is issued and revoked by Facilities under control CTL-PHY-03. Badges carry the holder's name, employee identifier, role, work e-mail, mobile number, date of birth, validity dates, a photograph and an encoded barcode value, and are therefore treated as personal data in their own right.

Figure 13 — Issued access credential for a Group Executive Risk Committee member (evidence for control CTL-PHY-03).

22. Policy governance, breach and review

22.1 Ownership and maintenance

This policy is owned by the Group Chief Risk Officer, [redacted]), and maintained by [redacted], Head of Enterprise Risk Framework [redacted]). The owner is accountable for keeping it current, ensuring subordinate documents remain aligned, and reporting on its effectiveness to the Board Risk Committee.

22.2 Review cycle and amendment

The policy is reviewed at least annually. Out-of-cycle review is triggered by a material change to strategy, structure or business model; a material change to applicable regulation; a Critical-rated incident or material regulatory finding relating to risk management; a material change to the appetite statement; or a recommendation from Group Internal Audit or the Board Risk Committee.

Material amendments require Board Risk Committee approval. Non-material amendments — typographical corrections, role title updates, references and formatting — may be approved by the Group CRO and are reported to the Board Risk Committee at its next meeting. Where there is doubt, the amendment is treated as material.

22.3 Policy breach

Failure to comply with this policy is a breach and may constitute misconduct. Breaches are recorded as incidents under Section 16 and investigated proportionately. The following are treated as serious breaches and reported to the Board Risk Committee individually:

- Failure to report a known incident, near miss or loss event.
- Knowingly false or misleading attestation, assessment or report.
- Operating outside an approved limit without escalation.
- Operating under an expired risk acceptance or exception.
- Amending a limit or a rating to conceal or cure a breach.
- Retaliation against an individual who has raised a concern in good faith.
- Obstructing the second or third line in the performance of their duties.

Confirmed breaches are referred to Human Resources (D. [redacted] for consideration under the disciplinary process and, for material risk takers, reported to the Remuneration Committee for consideration of variable-pay adjustment.

22.4 Breach determinations — H1 2026

REFERENCE	BREACH	INDIVIDUAL	DETERMINED BY	OUTCOME
PBR-2026-008	Re-scored residual rating without control change	Withheld pending appeal [redacted]	Ifeoma [redacted]	Referred to RemCo
PBR-2026-005	Incident reported 4 days after awareness	[redacted] (MER-PH-2214)	[redacted]	Written warning
PBR-2026-003	Operated under expired exception EXC-2025-097	[redacted]	[redacted]	Coaching; exception renewed

22.5 Interpretation

Questions of interpretation are determined by the Group Risk function. Where interpretation has Group-wide consequence, the determination is recorded and published on the Group Policy Portal so that it is applied consistently. Local interpretations narrowing a Group requirement are permitted; those widening it are not.

22.6 Effectiveness measures

MEASURE	TARGET	MEASURE OWNER	REPORTED TO
RCSA completed on time	100%	[redacted]	Group Executive Risk Committee
Critical and High issues overdue	Zero	[redacted]	Board Risk Committee
Incidents reported within one business day	≥ 95%	[redacted]	Operational Risk Committee
Issues self-identified by the first line	≥ 70% of total raised	[redacted]	Board Risk Committee
Risk acceptances expired without action	Zero	[redacted]	Group Executive Risk Committee
Exceptions extended more than once	≤ 10% of open exceptions	[redacted]	Group Executive Risk Committee
Mandatory risk training completion	≥ 95%	[redacted]	Board Risk Committee
Ad-hoc risk data requests met within timeframe	≥ 90%	[redacted]	Board Risk Committee

Appendix A — Impact and likelihood scales

A.1 Impact scale

Impact is assessed against every dimension below, and the overall rating is the **highest** attained on any single dimension. Impact is not averaged across dimensions.

RATING	FINANCIAL (SINGLE EVENT)	REGULATORY	CUSTOMER	OPERATIONAL	REPUTATIONAL
5 — Severe	> USD 50m	Licence condition, enforcement action or public censure	Widespread detriment; systemic redress required	Important business service unavailable beyond impact tolerance	Sustained international adverse coverage; loss of stakeholder confidence
4 — Major	USD 10m – 50m	Formal regulatory finding with mandated remediation	Significant detriment to a defined customer group	Material disruption to a core process exceeding one business day	Sustained national adverse coverage
3 — Moderate	USD 1m – 10m	Reportable breach; supervisory attention	Detriment to a limited group; individual redress required	Disruption contained within one business day	Trade or regional press coverage
2 — Minor	USD 100k – 1m	Technical breach, self-reported and remediated	Isolated detriment; straightforward remedy	Localised disruption absorbed within normal capacity	Limited internal or client-level concern
1 — Insignificant	< USD 100k	No breach; observation only	No customer detriment	Negligible disruption	No external awareness

A.2 Likelihood scale

RATING	DESCRIPTOR	FREQUENCY-BASED GUIDANCE	PROBABILITY-BASED GUIDANCE (12 MONTHS)
5	Almost certain	Expected to occur more than once a year	Greater than 90%
4	Likely	Expected to occur once within 1–2 years	60% – 90%
3	Possible	Could occur once within 2–5 years	25% – 60%
2	Unlikely	Could occur once within 5–10 years	5% – 25%
1	Rare	May occur once in more than 10 years	Less than 5%

> **Applying the scales.** Likelihood for inherent assessment assumes the absence of controls. Likelihood for residual assessment reflects controls assessed as effective. Where an event has already occurred within the assessment period, residual likelihood may not be rated below 3 (Possible) without documented justification approved by the second line. Scale interpretation queries are directed to [redacted].

A.3 Financial thresholds by legal entity

The thresholds in A.1 apply at Group level. Legal entities apply scaled thresholds proportionate to their size, approved annually by the Group Executive Risk Committee, so that a risk material to a smaller entity is not obscured on consolidation.

LEGAL ENTITY	SEVERE (5) THRESHOLD	THRESHOLD OWNER	LAST APPROVED
Cadence Financial Group, Inc. (Group)	USD 50m	[redacted]	12 Feb 2026
Cadence Financial Group (UK) Limited	GBP 18m	[redacted] (DIR-0058)	12 Feb 2026
Cadence Asset Management Europe SA	EUR 9m	[redacted]	12 Feb 2026
Cadence Services India Private Limited	INR 420m	[redacted]	12 Feb 2026
Cadence Capital Markets (Singapore) Pte	SGD 12m	[redacted]	12 Feb 2026

A.4 Velocity

For emerging risks and scenario work, velocity is recorded alongside impact and likelihood. Velocity does not change the score but informs prioritisation: a risk that could crystallise within days demands a different response from one with a multi-year onset, even at the same score.

VELOCITY	TIME FROM ONSET TO FULL IMPACT	IMPLICATION FOR TREATMENT
Very high	Less than 1 week	Pre-prepared response required; controls must be preventive or automated detective
High	1 week – 3 months	Contingency plan required and tested
Medium	3 – 12 months	Monitored through KRIs with defined trigger points
Low	More than 12 months	Managed through the planning cycle

Appendix B — Risk appetite statements and limits

The measures below give effect to the qualitative statements in Section 8.3. Each is reported monthly to the Group Executive Risk Committee and quarterly to the Board Risk Committee. Limits are approved by the Board; tolerance bands by the Group Executive Risk Committee.

CATEGORY	MEASURE	LIMIT	TOLERANCE BAND	NAMED OWNER	CONTACT
Capital	Common Equity Tier 1 ratio	≥ 12.5%	12.5% – 13.5%	[redacted]	[redacted]
	Leverage ratio	≥ 4.5%	4.5% – 5.0%	[redacted]	[redacted]
Liquidity	Liquidity coverage ratio	≥ 120%	120% – 135%	[redacted]	[redacted]
	Net stable funding ratio	≥ 110%	110% – 118%	[redacted]	[redacted]
Credit	Non-performing loan ratio	≤ 2.5%	2.0% – 2.5%	[redacted]	[redacted]
	Single-name exposure as % of CET1	≤ 10%	8% – 10%	[redacted]	[redacted]
Market	Trading book VaR (1-day, 99%)	≤ USD 18m	USD 14m – 18m	[redacted]	[redacted]
	VaR backtesting exceptions	≤ 4 per year	3 – 4	[redacted]	[redacted]
Operational	Operational losses as % of gross income	≤ 3.0%	2.4% – 3.0%	[redacted]	[redacted]
	Open Critical and High issues past due	0	zero appetite	[redacted]	[redacted]
	Severity 1 incidents (rolling 12 months)	≤ 4	3 – 4	[redacted]	[redacted]
Technology & cyber	Availability of important business services	≥ 99.9%	99.90% – 99.95%	[redacted]A.[redacted]	[redacted]
	Critical vulnerabilities open beyond SLA	0	zero appetite	[redacted]	[redacted]
	Unsupported software in critical services	0	zero appetite	[redacted]	[redacted]
Third party	Tier 1 providers without current assessment	0	zero appetite	[redacted]	[redacted]
	Tier 1 providers without a tested exit plan	0	zero appetite	[redacted]	[redacted]
Conduct & compliance	Material regulatory breaches	0	zero appetite	[redacted]	[redacted]
	Complaints upheld by the ombudsman	≤ 15%	12% – 15%	[redacted]	[redacted]
Financial crime	Overdue suspicious activity reviews	0	zero appetite	[redacted]	[redacted]
	Customers without current due diligence	≤ 0.5%	0.3% – 0.5%	[redacted]	[redacted]
Data privacy	Reportable personal data breaches	0	zero appetite	[redacted]	[redacted]
	Subject access requests within deadline	100%	zero appetite	[redacted]	[redacted]
People & culture	Mandatory risk training completion	≥ 95%	95% – 97%	[redacted]	[redacted]
	Voluntary attrition in control functions	≤ 12%	10% – 12%	[redacted]	[redacted]
Climate	Financed emissions against pathway	On or below	0 – 3% above	[redacted]	[redacted]

Measurement basis. Each measure has a documented definition covering calculation, data source, as-at convention, treatment of exclusions and responsible producer. Definitions are held in the Appetite Measurement Standard (GRP-STD-002) and may only be changed with Group Executive Risk Committee approval. Changing a definition in a way that alters a reported position requires restatement of prior periods.

Appendix C — RACI matrix and named accountable officers

R = Responsible | A = Accountable (single owner) | C = Consulted | I = Informed

ACTIVITY	BOARD	BRC	CEO	GRP CRO	DIV. CEO	RISK OWNER	2ND LINE	IA
Approve risk appetite statement	A	R	C	R	C	I	C	I
Approve this policy	I	A	C	R	C	I	R	C
Maintain the risk taxonomy	I	I	I	A	C	C	R	I
Cascade appetite to divisions	I	I	C	A	R	C	R	I
Identify risks	I	I	I	C	A	R	C	I
Perform RCSA	—	I	I	C	A	R	C	I
Attest RCSA outcome	—	I	I	I	A	R	C	I
Challenge RCSA	—	I	I	A	C	C	R	I
Assess control effectiveness	—	I	I	C	A	R	C	C
Develop treatment plans	—	I	I	C	A	R	C	I
Approve Critical risk acceptance	I	A	C	R	R	C	C	I
Approve High risk acceptance	I	I	C	A	R	C	C	I
Raise and rate issues	—	I	I	C	A	R	R	R
Remediate issues	—	I	I	I	A	R	C	I
Verify issue closure	—	I	I	A	I	C	R	R
Report incidents	—	I	I	I	A	R	C	I
Investigate Severity 1 incidents	I	I	A	R	R	C	R	C
Determine regulatory notification	I	I	A	C	C	I	R	I
Define and report KRIs	—	I	I	A	C	R	R	I
Conduct scenario analysis	I	C	C	A	R	R	R	C
Approve new products	—	I	I	A	R	R	C	I
Assess third-party risk	—	I	I	C	A	R	R	I
Approve policy exceptions	—	C	I	A	R	R	C	I
Report the Group risk profile	I	I	C	A	C	C	R	I
Assure the framework	I	C	I	C	I	I	C	A
Deliver risk training	—	I	I	A	R	I	R	I
Assess risk culture	I	C	C	A	R	I	R	C

C.1 Named accountable officers

RACI COLUMN	CURRENT INCUMBENT	EMP / DIR ID	CORPORATE E-MAIL	DIRECT LINE
Board	[redacted] (Chair)	DIR-0001	[redacted]	[redacted]
BRC	[redacted]	DIR-0042	[redacted]	[redacted]
CEO	[redacted]	[redacted]	[redacted]	[redacted]
Group CRO	[redacted]	[redacted]	[redacted]	[redacted]
Div. CEO (Consumer)	[redacted]	[redacted]	[redacted]	[redacted]
Risk owner (example)	[redacted]	[redacted]	[redacted]	[redacted]
2nd line	[redacted]	[redacted]	[redacted]	[redacted]
Internal Audit	[redacted]	[redacted]	i.[redacted]	[redacted]

BRC — Board Risk Committee. IA — Group Internal Audit. "2nd line" denotes the Group Risk, Compliance and Data Privacy functions collectively. Where a cell shows "—", the party has no defined involvement.

Appendix D — Key risk indicator catalogue

The following is the mandatory minimum indicator set. Divisions maintain additional indicators approved by their Divisional Risk Committee and registered with the Group Risk function.

CATEGORY	INDICATOR	TYPE	FREQ.	AMBER	RED	INDICATOR OWNER
Credit	Early arrears (30+ days) as % of book	Leading	Monthly	1.5% – 2.0%	> 2.0%	[redacted]
	Watchlist exposures as % of CET1	Leading	Monthly	4% – 6%	> 6%	[redacted]
	Covenant breaches in the period	Lagging	Monthly	3 – 5	> 5	[redacted]
Market	VaR utilisation against limit	Leading	Daily	75% – 90%	> 90%	[redacted]
	Stressed VaR utilisation	Leading	Weekly	70% – 85%	> 85%	[redacted]
Liquidity	LCR headroom above limit	Leading	Daily	10 – 15 pts	< 10 pts	[redacted]
	Wholesale funding concentration, top 10	Leading	Weekly	25% – 30%	> 30%	[redacted]
Operational	Open Critical and High issues past due	Lagging	Monthly	1 – 5	> 5	[redacted]
	Incidents reported within SLA	Lagging	Monthly	90% – 95%	< 90%	[redacted]
	Manual workarounds in critical processes	Leading	Monthly	5 – 10	> 10	[redacted]
	Key control testing completed on time	Leading	Monthly	90% – 95%	< 90%	[redacted]
Technology & cyber	Critical vulnerabilities open beyond SLA	Leading	Weekly	1 – 3	> 3	[redacted]
	Privileged accounts without review	Leading	Monthly	1 – 5	> 5	[redacted]
	Change failure rate	Lagging	Monthly	3% – 5%	> 5%	[redacted]
	Backup restoration tests failed	Leading	Quarterly	1	> 1	[redacted]
Third party	Tier 1 providers with overdue assessment	Leading	Monthly	1 – 2	> 2	[redacted]
	Provider SLA breaches, Tier 1 and 2	Lagging	Monthly	3 – 6	> 6	[redacted]
Conduct & compliance	Complaints per 1,000 customers	Lagging	Monthly	2.0 – 3.0	> 3.0	[redacted]
	Regulatory deadlines missed	Lagging	Monthly	1	> 1	[redacted]
	Overdue suspicious activity reviews	Leading	Weekly	1 – 5	> 5	[redacted]
Data privacy	Personal data incidents reported	Lagging	Monthly	1 – 3	> 3	[redacted]
	Subject access requests near deadline	Leading	Weekly	1 – 3	> 3	[redacted]
People & culture	Control function vacancy rate	Leading	Monthly	8% – 12%	> 12%	[redacted]
	Mandatory training overdue	Leading	Monthly	3% – 5%	> 5%	[redacted]
	Speak Up cases open beyond SLA	Lagging	Monthly	1 – 2	> 2	[redacted]

Threshold review. Thresholds are reviewed annually, and whenever an indicator has remained red or green without variation for four consecutive quarters, to confirm they remain calibrated to provide a useful signal rather than persistent noise or false comfort. Review is coordinated by [redacted].

Appendix E — Related documents, approval and version control

E.1 Subordinate policies and owners

REFERENCE	DOCUMENT	OWNER	CONTACT
GRP-POL-002	Credit Risk Policy	[redacted]	[redacted]
GRP-POL-003	Market Risk Policy	[redacted]	[redacted]
GRP-POL-004	Liquidity and Funding Risk Policy	[redacted]	[redacted]
GRP-POL-005	Operational Risk Policy	[redacted]	[redacted]
GRP-POL-008	Compliance Policy	[redacted]	[redacted]
GRP-POL-009	Financial Crime and Sanctions Policy	[redacted]	[redacted]
GRP-POL-011	Conduct Risk and Customer Outcomes Policy	[redacted]	[redacted]
GRP-POL-014	Technology and Cyber Risk Policy	[redacted]	[redacted]
GRP-POL-015	Third-Party Risk Management Policy	[redacted]	[redacted]
GRP-POL-016	Business Continuity and Resilience Policy	[redacted]	[redacted]
GRP-POL-018	Model Risk Management Policy	[redacted]	[redacted]
GRP-POL-021	Data Privacy Policy	[redacted]	[redacted]
GRP-POL-022	Data Governance and Records Policy	[redacted]	[redacted]
GRP-POL-026	Climate and Environmental Risk Policy	[redacted]	[redacted]

E.2 Supporting standards and procedures

REFERENCE	DOCUMENT	OWNER
GRP-STD-001	Risk Taxonomy Standard	[redacted]
GRP-STD-002	Appetite Measurement Standard	[redacted]
GRP-STD-004	Risk Assessment Standard	[redacted]
GRP-STD-006	RCSA Standard	[redacted]
GRP-STD-007	Issue Management Standard	[redacted]
GRP-STD-008	Incident and Loss Data Standard	[redacted]
GRP-STD-010	Key Risk Indicator Standard	[redacted]
GRP-STD-012	Scenario and Stress Testing Standard	[redacted]
GRP-PRO-003	Risk Acceptance and Exception Procedure	[redacted]

E.3 Version history

VERSION	DATE	AUTHOR	APPROVED BY	SUMMARY OF CHANGE
1.0	1 July 2018	[redacted]	Board Risk Cttee	Initial issue following framework consolidation
3.0	1 July 2021	[redacted]	Board Risk Cttee	Operational resilience and impact tolerances added
4.0	1 July 2022	[redacted]	Board Risk Cttee	Climate risk added to taxonomy; appetite framework restructured
5.0	1 July 2024	[redacted]	Board Risk Cttee	Third-party tiering revised for DORA; model risk section added
5.1	3 Feb 2025	[redacted]	[redacted]	Non-material: Appendix D thresholds recalibrated
5.2	1 July 2025	[redacted]	Board Risk Cttee	Issue extension controls strengthened; overdue issues made a Board appetite measure
6.0	**1 July 2026**	[redacted]	**Board Risk Cttee**	**Data privacy elevated to zero appetite; velocity introduced (A.4); acceptance durations and re-approval escalation added (12.3); prohibited treatments codified (12.5); BCBS 239 aggregation testing added (19.4); named accountable officers published (Appendix C.1)**

E.4 Approval record

ROLE	NAME	CONTACT	ACTION	DATE
Head of Enterprise Risk Framework	[redacted]	[redacted]	Drafted	21 Apr 2026
Group Executive Risk Committee	[redacted]	[redacted]	Recommended	28 May 2026
Group General Counsel	[redacted]	[redacted]	Legal review	4 Jun 2026

Chief Privacy Officer	[redacted]	[redacted]	Privacy review	6 Jun 2026
Group Chief Risk Officer	[redacted]	[redacted]	Endorsed	9 Jun 2026
Board Risk Committee Chair	[redacted] (DIR-0042)	[redacted]	Approved	18 Jun 2026
Board Chair	[redacted] (DIR-0001)	[redacted]	Noted	25 Jun 2026

E.5 Confidentiality and handling

This document is classified Internal and contains the personal data of named officers, together with register extracts containing employee identifiers, dates of birth, national identifiers, home addresses and photographic images. Any interception, review, retransmission or other use by persons other than the intended recipient is prohibited. Distribution outside the Group requires the approval of the Chief Privacy Officer.

> **Training artifact disclaimer.** Cadence Financial Group, Meridian Staffing, Northwind Analytics, Veritrace Screening Services, Halloran & Pike LLP and AegisGRC are fictional. All names, e-mail addresses, telephone numbers, employee and director identifiers, national identifiers, account numbers, addresses and dates in this document were generated for PII-detection teaching purposes and correspond to no real person or organisation. Identifier values follow published test formats and are not usable.

E.6 Exercise prompts for students

1. Extract text from every page and report which pages required optical character recognition.
2. Enumerate all PII instances by category, with page and location references, distinguishing body text, tables, narrative prose and image-only occurrences.
3. Identify every identifier that appears only inside an image, and measure the recall difference against digitally native text.
4. Locate identifiers embedded in unlabelled narrative prose (Sections 16.5 and 16.8) and explain why field-based extraction fails there.
5. Produce a masked derivative that preserves page count, layout and cross-artifact traceability of individuals via stable tokens.
6. Justify the false-positive controls you would apply to PAN, PESEL, TIN and card-number patterns.